

• **Expediente N.º: EXP202305979**

ÍNDICE DE CONTENIDOS

<u>RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR.....</u>	<u>3</u>
<u>ANTECEDENTES.....</u>	<u>3</u>
<u>PRIMERO.....</u>	<u>3</u>
<u>SEGUNDO:.....</u>	<u>3</u>
<u>Primera notificación de la violación de seguridad de los datos personales.....</u>	<u>3</u>
<u>Segunda notificación de la violación de seguridad de los datos personales.....</u>	<u>5</u>
<u>Tercera notificación de la violación de seguridad de los datos personales.....</u>	<u>6</u>
<u>Cuarta notificación de la violación de seguridad de los datos personales.....</u>	<u>7</u>
<u>Quinta notificación de la violación de seguridad de los datos personales.....</u>	<u>8</u>
<u>RESULTADO DE LAS ACTUACIONES DE INVESTIGACIÓN.....</u>	<u>9</u>
<u>TERCERO.....</u>	<u>23</u>
<u>CUARTO.....</u>	<u>23</u>
<u>QUINTO.....</u>	<u>24</u>
<u>SEXTO.....</u>	<u>24</u>
<u>ALEGACIÓN PREVIA.....</u>	<u>24</u>
<u>ALEGACIÓN PRIMERA. Aclaraciones previas sobre los incidentes de seguridad sufridos por CCC.....</u>	<u>24</u>
<u>ALEGACIÓN SEGUNDA. CCC no ha infringido el principio de integridad y confidencialidad.....</u>	<u>26</u>
<u>ALEGACIÓN TERCERA: CCC adoptó medidas de seguridad apropiadas.....</u>	<u>30</u>
<u>ALEGACIÓN CUARTA. CCC reconoce su responsabilidad en relación con la presunta infracción del artículo 34 de RGPD: comunicación de las brechas a las personas afectadas.....</u>	<u>33</u>
<u>ALEGACIÓN QUINTA. Listado de prueba documental.....</u>	<u>33</u>
<u>SÉPTIMO:</u>	<u>34</u>
<u>OCTAVO.....</u>	<u>34</u>
<u>NOVENO.....</u>	<u>34</u>
<u>DÉCIMO.....</u>	<u>35</u>
<u>UNDÉCIMO.....</u>	<u>35</u>
<u>DUODÉCIMO.....</u>	<u>38</u>
<u>DECIMOTERCERO.....</u>	<u>38</u>
<u>HECHOS PROBADOS.....</u>	<u>38</u>

PRIMERO.....	38
Primera violación de la seguridad de los datos personales.....	38
Segunda violación de la seguridad de los datos personales.....	40
Tercera violación de la seguridad de los datos personales.....	42
Cuarta violación de la seguridad de los datos personales.....	43
Quinta violación de la seguridad de los datos personales.....	45
SEGUNDO.....	46
TERCERO.....	47
CUARTO:.....	47
QUINTO.....	49
SEXTO.....	51
SÉPTIMO.....	52
OCTAVO.....	52
NOVENO.....	52
DÉCIMO.....	52
UNDÉCIMO.....	54
FUNDAMENTOS DE DERECHO.....	54
I Competencia.....	55
II Cuestiones Previas.....	55
III Respuesta a las alegaciones al acuerdo de inicio.....	57
ALEGACIÓN PRIMERA.....	57
ALEGACIÓN SEGUNDA.....	58
ALEGACIÓN TERCERA.....	64
ALEGACIÓN CUARTA.....	73
IV Obligación incumplida. Principio de integridad y de confidencialidad.....	74
V Tipificación y calificación de la infracción.....	78
VI Sanción.....	79
VII Obligación incumplida. Seguridad del tratamiento.....	82
VIII Tipificación y calificación de la infracción.....	87
IX Sanción.....	88
X Obligación incumplida. Comunicación de una violación de seguridad de los datos personales al interesado.....	90
XI Tipificación y calificación de la infracción.....	92

XII Sanción.....	93
XIII Adopción de medidas.....	95
RESOLUCIÓN.....	96

RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: En fecha 18 y 21 de abril de 2023, se notificó a la División de Innovación Tecnológica de esta Agencia, una brecha de seguridad de los datos personales, remitido por CENTROS COMERCIALES CARREFOUR, S.A., (en lo sucesivo, Carrefour o CCC) con NIF A28425270, como responsable del tratamiento, con números de registro de entrada REGAGE23e00025023252 y REGAGE23e00025776926, respectivamente, relativa al acceso no autorizado a datos personales del perfil de cliente.

Como consecuencia de los hechos conocidos, en fecha 3 de mayo de 2023, la Directora de la Agencia Española de Protección de Datos ordenó a la Subdirección General de Inspección de Datos (SGID) realizar las oportunas investigaciones previas con el fin de determinar una posible vulneración de la normativa de protección de datos.

SEGUNDO: La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), y de conformidad con lo establecido en el Título VII, Capítulo I, Sección segunda, de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales (en adelante LOPDGDD), teniendo conocimiento de los siguientes extremos:

Primera notificación de la violación de seguridad de los datos personales: en fecha 13 de enero de 2023 y registro de entrada REGAGE23e00002601392, se recibe en esta Agencia notificación de brecha de seguridad de datos personales por parte del responsable de tratamiento Carrefour, con la siguiente información asociada:

(...)

Segunda notificación de la violación de seguridad de los datos personales: en fecha 20 de enero de 2023 y registro de entrada REGAGE23e00004163707, se recibe en esta Agencia notificación de brecha de seguridad de datos personales por parte del responsable de tratamiento Carrefour, con la siguiente información relevante:

(...)

Tercera notificación de la violación de seguridad de los datos personales: en fecha 24 de enero de 2023 y registro de entrada REGAGE23e00004641543, se recibe modificación de la brecha anterior, aportando un informe técnico del incidente. Este documento tiene fecha de creación 20 de enero de 2023 y de su análisis se extrae la siguiente información relevante:

(...)

Cuarta notificación de la violación de seguridad de los datos personales: en fecha 18 de abril de 2023 y registro de entrada REGAGE23e00025023252, se recibe nueva notificación de brecha por parte del responsable Carrefour, con la siguiente información relevante asociada:

(...)

Quinta notificación de la violación de seguridad de los datos personales: en fecha 21 de abril de 2023 y registro de entrada REGAGE23e00025776926, se recibe nueva entrada a través de la cual se amplía la información de la última brecha notificada el 18 de abril de 2023, en concreto:

(...)

RESULTADO DE LAS ACTUACIONES DE INVESTIGACIÓN

En fecha 23 de junio de 2023 se notifica requerimiento de información dirigido al responsable, Carrefour, marcado por la siguiente línea de investigación:

- Investigar la actividad de tratamiento afectada por la brecha.
- Investigar los procedimientos implantados para gestionar brechas de seguridad.
- Investigar los análisis de riesgos y posibles evaluaciones de impacto realizadas.
- Investigar las medidas preventivas y reactivas implantadas.
- Investigar las comunicaciones a los afectados, medios utilizados y fechas en la que se realizó.

En fecha posterior a la notificación del requerimiento anterior se recibe en esta Agencia una nueva notificación de brecha de seguridad por parte de CARREFOUR, con fecha 26 de junio de 2023 y registro de entrada REGAGE23e00041661209. De su análisis se extrae la información relevante:

(...)

En fecha 7 de julio de 2023 y registro de entrada REGAGE23e00045766091 se recibe respuesta por parte de CARREFOUR al requerimiento de información notificado el 23 de junio de 2023, del análisis de la documentación aportada se extrae la siguiente información relevante para la investigación:

- Se aporta el Registro de Actividades de Tratamiento (RAT) con información muy detallada de la actividad afectada por la brecha, en concreto:

- o Actividad: “*Cientes Club Carrefour*”.
- o Finalidad: “*Gestión del club de fidelización, Servicio de atención al cliente, Gestión de la publicidad, Prevención del fraude, Realización de perfilado, Análisis de comportamiento del cliente. Evaluación de clientes potenciales, Estudio de mercado, Marketing directo, Fines contractuales*”.
- o Datos afectados: *Código Postal, frecuencia de consumo, fecha de nacimiento, datos de familiares de primer grado, dirección de facturación, fecha de nacimiento de los hijos, nombre, información de geolocalización, domicilio particular, intereses y preferencias comerciales de comunicación, apellidos, estado civil, número de DNI, nacionalidad, número de identificación en el extranjero (NIE), número de pasaporte, dirección de email personal, números de teléfono, tendencias de compra, sexo.*
- o Medidas de minimización y gobernanza:
 - (...)
- o Medidas técnicas:
 - (...)
- o Medidas minimización sobre concepto y diseño:
 - (...).
- Aportan documento con el procedimiento interno existente para la gestión de brechas de seguridad, del análisis de este documento se extrae la siguiente información relevante:

(...)

TERCERO: De acuerdo con el informe recogido de la herramienta AXESOR, la entidad CENTROS COMERCIALES CARREFOUR, S.A., es una gran empresa constituida en el año 1976, y con un volumen de negocios de 9.027.949.000 € euros, en el año 2022.

CUARTO: En fecha 29 de abril de 2024, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a la entidad investigada, con arreglo a lo dispuesto en los artículos 63 y 64 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), por la presunta infracción del artículo 5.1.f) del RGPD, tipificada en el artículo 83.5 del RGPD, por la presunta infracción del artículo 32 del RGPD, tipificada en el artículo 83.4 del RGPD y por la presunta infracción del artículo 34 del RGPD, tipificada en el artículo 83.4 del RGPD.

El acuerdo de inicio fue enviado conforme a las normas establecidas en la LPACAP, mediante notificación electrónica, siendo recibido en fecha 30 de abril de 2024, como consta en el certificado que obra en el expediente.

QUINTO: Habiendo solicitado la ampliación del plazo que le fue concedido para formular alegaciones, en virtud de lo establecido en el artículo 32.1 de la LPACAP, en fecha 6 de mayo de 2024, se acordó ampliar dicho plazo hasta un máximo de cinco días, que debían computarse a partir del día siguiente a aquel en el que finalizara el primer plazo de alegaciones.

SEXTO: Notificado el citado acuerdo de inicio conforme a las normas establecidas en la LPACAP, la entidad investigada presentó escrito de alegaciones en el que, en síntesis, manifiesta:

ALEGACIÓN PREVIA

- que no ha infringido los artículos 5.1 f) y 32 del RGPD. A esta cuestión dedica las Alegaciones Segunda y Tercera.

-pone de manifiesto que reconoce la responsabilidad por la presunta infracción del artículo 34 del RGPD, relativa a la comunicación de las brechas a las personas afectadas. A esta cuestión dedica la Alegación Cuarta.

-y dedica la Alegación Quinta a enumerar los documentos aportados por CCC junto con el presente escrito de alegaciones.

Antes de exponer las razones por las que considera que no se ha producido una infracción de los artículos 5.1 f) y 32 del RGPD, realiza una serie de aclaraciones sobre la naturaleza y dinámica de los ataques que dieron lugar a los incidentes sufridos por CCC.

ALEGACIÓN PRIMERA. Aclaraciones previas sobre los incidentes de seguridad sufridos por CCC

En primer lugar, en cuanto a la obtención de credenciales, manifiesta que los incidentes tuvieron su origen en la obtención de credenciales (usuario y contraseña) por parte de un tercero. La obtención de estas credenciales se produce en un entorno ajeno a CCC. Es decir, el acceso a este primer dato personal (credenciales) no se produce en bases de datos de las que sea responsable CCC. A este respecto señala que la función hash utilizada para proteger las credenciales hoy en día es considerada robusta. Aporta como documento explicativo el Documento 1.

En segundo lugar, en cuanto a las peticiones de acceso, señala que el número de cuentas afectadas informado a la Agencia en cada una de las brechas de seguridad comunicadas se corresponde con el número de cuentas respecto de las que el tercero obtuvo confirmación de la validez de las credenciales, no se trata de cuentas a las que el tercero tuviera acceso, ni que haya tenido acceso a los datos personales de esos clientes.

En tercer lugar, una vez el tercero ha confirmado la validez de las credenciales, procede a su venta por distintos canales. Aporta como Documento 2, dos capturas de pantalla de canales de *****APP.1** en las que se puede observar cómo se ofrecen credenciales de distintos comercios, CCC inclusive. De esta forma, el tercero obtendrá una contraprestación económica derivada de la venta de estas credenciales

verificadas y, por su parte, el tercero que compre las credenciales podrá utilizarlas para acceder a la zona de cliente y tratar de cometer un fraude económico mediante la utilización del chequeAhorro.

No obstante, señala que hay que tener en cuenta que el acceso no se producirá si: no hay comprador o el comprador no llega a utilizar las credenciales; si las credenciales comprometidas se han reseteado; y/o se ha implementado un factor de doble autenticación.

Asimismo, realiza algunas aclaraciones adicionales:

Entiende que no se ha producido un acceso no autorizado o ilícito a 118.895 cuentas de clientes y, por ende, una afectación de la integridad y/o confidencialidad de los datos personales de los titulares de dichas cuentas en todos estos casos.

Considera que sólo hay 234 casos en los que se ha visto afectada la integridad de los datos personales de los clientes; y 973 casos en los que se ha visto afectada la confidencialidad de los Datos Personales Afectados.

La Primera, Segunda, Tercera y Cuarta Brecha afectaron a la aplicación de CCC, mientras que la Quinta Brecha afectó a la página web.

(...)

En relación con las pruebas de penetración (también conocidos como pentest) realizados tras la Primera Brecha, desea aclarar que no se trata de medidas adoptadas de forma reactiva y que en CCC se realizan pentest de forma periódica tanto para la web como para la aplicación desde antes de los incidentes. En este sentido aclara en cuanto a los resultados obtenidos, que para la realización de las auditorías se desactivaron determinadas medidas de seguridad (caja gris), de ahí que las recomendaciones y mejoras detectadas en dichas auditorías no se correspondan con la realidad y deban matizarse.

Partiendo de la base de las aclaraciones realizadas en esta Alegación Primera, a continuación, pasa a valorar la existencia de infracción de los artículos 5.1 f) (Alegación Segunda) y 32 del RGPD (Alegación Tercera).

ALEGACIÓN SEGUNDA. CCC no ha infringido el principio de integridad y confidencialidad.

Reitera que la afectación de la confidencialidad de los datos personales de clientes de CCC se ha producido en sólo 973 casos.

En relación con la integridad, los casos en los que la misma se vio afectada ascienden a 234. En este sentido, hay que tener en cuenta que:

a) Tal y como se comunicó en la Primera Brecha, se ha comprobado que solo hubo 234 casos de clientes cuyos datos personales se vieran modificados. Los datos que se modificaron fueron la dirección de correo electrónico, la dirección de entrega, así como, en algunos casos, el número de teléfono y el nombre.

b) De hecho, el 14 de marzo se implementó el doble factor de autenticación para modificar los datos personales desde la zona cliente, por lo que la integridad de los datos personales no se vio comprometida en el resto de las brechas.

En relación con la confidencialidad, los casos en los que la misma se vio afectada ascienden a 973. Este número se corresponde con los casos en los que se ha detectado un fraude en el cheque Ahorro de los clientes, que se reparten entre: (i) los 234 casos de la Primera Brecha, donde la afectación de la integridad también comportó una afectación de la confidencialidad; y (ii) 739 casos repartidos entre la Segunda y la Quinta Brecha.

El reseteo de las credenciales impide que el comprador pueda acceder a la zona de cliente de la persona afectada.

(...)

Por tanto, la suma de las personas afectadas reportada en las brechas (118.895) no se corresponde con la totalidad de casos en los que la integridad y la confidencialidad se viera afectada, sino que la afectación de la integridad se limitó a 234 clientes y la afectación de la confidencialidad a 973.

Indica que CCC sí adoptó medidas técnicas y organizativas adecuadas para evitar que la pérdida de la integridad y confidencialidad se volviera a producir y, en cualquier caso, para reducir eficazmente la probabilidad de materialización de la pérdida de integridad y confidencialidad de los datos personales de sus clientes.

A continuación, incluye un listado de las medidas adoptadas con anterioridad a la primera violación de la seguridad de los datos personales.

Medidas técnicas:

(...)

Medidas organizativas:

(...)

Aporta como Documento 4 copia del acuerdo de prórroga y renovación del contrato de cibervigilancia y vulnerabilidades suscrito con *****EMPRESA.1**, que acredita que estos servicios estaban vigentes con anterioridad a la Primera Brecha.

(...)

Asimismo, aporta como Documento 9, un informe emitido por *****EMPRESA.2** en el que se concluye que el estado de cumplimiento de CCC es superior respecto al de otras entidades de referencia en el sector retail.

Por todo lo anterior, entiende que las medidas técnicas y organizativas adoptadas por CCC sí eran adecuadas para evitar que la pérdida de la integridad y confidencialidad

se volviera a producir o, como mínimo, para reducir eficazmente la probabilidad de materialización de la pérdida de integridad y confidencialidad de los datos personales de sus clientes.

Subsidiariamente, para el caso de que la Agencia entienda que ha existido infracción y deba imponerse una sanción a CCC, deberán tenerse en cuenta las siguientes circunstancias atenuantes:

- o La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido (artículo 83.2 a) del RGPD):

Entiende que debería reducirse la cuantía de la sanción teniendo en cuenta que, el número de afectados que han visto comprometida la integridad y/o confidencialidad de sus datos personales es de 973, no de 118.895. Además, considera que, a pesar de que en estos casos se haya visto afectado un conjunto de datos (nombre y apellidos, dirección postal completa y fecha de nacimiento), los mismos no son críticos, máxime si tenemos en cuenta que, como se ha expuesto (Documento 2), el fin último perseguido por el tercero es cometer un fraude económico, siendo los datos personales afectados un medio para cometer dicho fraude, no un fin en sí mismo.

- o La intencionalidad o negligencia en la infracción (artículo 83.2 b) del RGPD):

(...)

Además, CCC entiende que deberán tenerse en cuenta las siguientes circunstancias como atenuantes:

i. Cualquier otra medida tomada por el responsable del tratamiento para paliar los daños y perjuicios sufridos por los interesados (artículo 83.2 c) del RGPD).

Considera que debería ser tenida en cuenta como atenuante el hecho de que CCC tomara medidas para paliar los daños y perjuicios sufridos por los afectados. En este sentido: reseteó las credenciales que se habían visto afectadas; y en aquellos casos en los que se produjo un fraude en los chequesAhorro, CCC reembolsó el importe del chequeAhorro y emitió tarjetas regalo para las personas afectadas, de tal forma que éstas no sufrieron ningún impacto económico derivado del fraude.

Además, estas medidas fueron tomadas de forma espontánea, antes de que CCC tuviera constancia de los requerimientos de información y del inicio de la investigación de la Agencia.

ii. El grado de cooperación con la autoridad de control con el fin deponer remedio a la infracción y mitigar los posibles efectos adversos de la infracción (artículo 83.2 f) del RGPD), así como la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable notificó la infracción y, en tal caso, en qué medida (artículo 83.2 h del RGPD).

CCC considera que es de aplicación esta atenuante en la medida en que el Acuerdo de Inicio se ha dictado como consecuencia de las cinco brechas de seguridad comunicadas por CCC a la Agencia. Debe valorarse como atenuante el que se hubiera notificado, cumpliendo de forma diligente con este deber. Se proporcionó información con total transparencia y por ello también entiende que deberían ser de aplicación estas circunstancias atenuantes. Finalmente, CCC ha cooperado de forma favorable con la investigación, proporcionando respuesta a todos los requerimientos efectuados.

ALEGACIÓN TERCERA: CCC adoptó medidas de seguridad apropiadas.

Manifiesta que CCC adoptó medidas de seguridad apropiadas, sin perjuicio de que, si se entendieran infringidos los artículos 5.1 f) y 32 del RGPD (quod non), estaríamos ante una única infracción y que la supuesta falta de medidas técnicas y organizativas apropiadas debería entenderse comprendida, como medio de perpetración, en la infracción de los principios de integridad y confidencialidad.

(...)

En cuanto a los pentest de *****EMPRESA.1**, indica que CCC no realizó el pentest de forma reactiva tras la primera brecha. Los pentest forman parte de una amplia gama de medidas técnicas y organizativas adoptadas por CCC para preservar la confidencialidad, integridad y disponibilidad de los datos personales tratados.

Los pentest se realizaban – y se siguen realizando – de forma periódica tanto para la web como para la aplicación. A este respecto, se remite al contrato de prestación de servicios SOC suscrito con *****EMPRESA.1** (Documento 4), donde se incluye un servicio de auditoría de seguridad de aplicaciones web. Además, aporta como Documento 10 un certificado preparado por *****EMPRESA.1** en el que se certifican los pentest realizados con anterioridad a la Primera Brecha.

En este sentido, manifiesta que es cierto que en el informe se hace referencia a supuestas "*deficiencias en los controles implementados en los sistemas de información*" de CCC. No obstante, indica que hay que tener en cuenta que para la realización de las auditorías se desactivaron determinadas medidas de seguridad (caja gris), por lo que las recomendaciones y mejoras detectadas en dichas auditorías no se corresponden con la realidad y deben matizarse. Adjunta unas tablas, en las que se listan las recomendaciones a corto plazo identificadas en los pentest y se incluye una justificación de la no relevancia de las mismas.

Por todo lo anterior, entiende que las medidas técnicas y organizativas adoptadas por CCC sí eran apropiadas conforme a lo expuesto en el artículo 32 del RGPD. Subsidiariamente, para el caso de que la Agencia entienda que ha existido infracción y deba imponerse una sanción a CCC, considera que deberán tenerse en cuenta las siguientes circunstancias agravantes y atenuantes:

- o La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido (artículo 83.2 a) del RGPD)

Entiende que o se considera como agravante el hecho de que haya habido una afectación de los Datos Personales Afectados (en cuyo caso deberá limitarse a los clientes efectivamente afectados, no a todos los usuarios de la web y la aplicación) o, por el contrario, se considera como agravante el hecho de que la afectación por la falta de medidas técnicas y organizativas afecta a todos los usuarios de la web y la aplicación (en cuyo caso no podrá defenderse que ha habido una efectiva afectación de sus datos personales, puesto que la misma se ha producido solo en determinados casos).

En cualquier caso, considera que, a pesar de que en determinados casos se haya visto afectado un conjunto de datos (nombre y apellidos, dirección postal completa y fecha de nacimiento), los mismos no son críticos, máxime si tenemos en cuenta que el fin último perseguido por el tercero es cometer un fraude económico, siendo los datos personales afectados un medio para cometer dicho fraude, no un fin en sí mismo.

En relación con la duración, se ha visto cómo la aplicación progresiva de nuevas medidas fue reduciendo el impacto (implantación del segundo factor para modificar datos personales y para acceder a la aplicación, entre otros), por lo que entiende que esta circunstancia no podrá ser tenida en cuenta como agravante.

- o La intencionalidad o negligencia en la infracción (artículo 83.2 b) del RGPD

En la medida en que la argumentación de la Agencia es la misma que la utilizada al tratar esta circunstancia para la supuesta infracción del artículo 5.1 f) del RGPD, se remite a lo expuesto en relación con la misma en la Alegación Segunda.

Además, CCC entiende que deberán tenerse en cuenta las siguientes circunstancias como atenuantes:

i. Cualquier otra medida tomada por el responsable del tratamiento para paliar los daños y perjuicios sufridos por los interesados (artículo 83.2 c) del RGPD)

CCC adoptó medidas técnicas y organizativas dirigidas a disminuir la probabilidad de materialización del riesgo. Además, estas medidas fueron adoptadas de forma proactiva, esto es, con anterioridad a tener conocimiento de las investigaciones de la Agencia que han acabado en el dictado del Acuerdo de Inicio.

ii. El grado de cooperación con la autoridad de control con el fin deponer remedio a la infracción y mitigar los posibles efectos adversos de la infracción (artículo 83.2 f) del RGPD), así como la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable notificó la infracción y, en tal caso, en qué medida (artículo 83.2 h del RGPD).

Se remite a lo expuesto para esta circunstancia en la Alegación Segunda.

ALEGACIÓN CUARTA. CCC reconoce su responsabilidad en relación con la presunta infracción del artículo 34 de RGPD: comunicación de las brechas a las personas afectadas.

Aunque CCC consideró en su momento que no era preceptiva la comunicación de las brechas a las personas afectadas, CCC reconoce su responsabilidad única y exclusivamente por la presunta infracción del artículo 34 del RGPD, en relación con aquellas personas que vieron afectadas la confidencialidad y/o integridad de sus datos personales, lo que deberá llevar aparejada una reducción de un 20% de la sanción propuesta para esta infracción (200.000 euros). Asimismo, en caso de que el pago se realizara antes de la resolución del presente procedimiento, la sanción debería reducirse en un 20% adicional, siendo la cuantía a pagar 120.000 euros.

ALEGACIÓN QUINTA. Listado de prueba documental aportada, a los efectos de demostrar la ausencia de infracción o, en su caso, modular a la baja la sanción propuesta por la Agencia.

- a) Como Documento 1, documento explicativo de la función hash utilizada por *****EMPRESA.3**.
- b) Como Documento 2, capturas de pantalla de canales de *****APP.1** en los que se ofrecían credenciales de clientes de CCC.
- c) Como Documento 3, capturas de pantalla de canales de *****APP.1** en los que se mencionaba la imposibilidad de utilizar las credenciales adquiridas.
- d) Como Documento 4, copia del acuerdo de prórroga y renovación del contrato de cibervigilancia y vulnerabilidades suscrito con *****EMPRESA.1**.
- e) Como Documento 5, copia del informe de auditoría de *****EMPRESA.4** (2022).
- f) Como Documento 6, copia de la matriz de cumplimiento de CCC (...).
- g) Como Documento 7, información sobre la implementación del segundo factor de autenticación en los canales digitales de otros comercios líderes en España.
- h) Como Documento 8, documento en el listado de llamadas a (...) de *****EMPRESA.3**.
- i) Como Documento 9, copia del informe emitido por *****EMPRESA.2** de mayo de 2024.
- j) Como Documento 10, copia de un certificado de *****EMPRESA.1** en el que se listan los pentest realizados con anterioridad a la Primera Brecha.

En virtud de todo lo anterior, solicita en relación con la presunta infracción del artículo 34 del RGPD, tener por reconocida la responsabilidad de Centros Comerciales Carrefour, S.A y en relación con las presuntas infracciones de los artículos 5.1 f) y 32 del RGPD: el sobreseimiento del expediente con el consiguiente archivo de las actuaciones, por no haberse cometido ninguna de las infracciones imputadas. Subsidiariamente, que, en caso de imponerse alguna sanción, se imponga en cuantía mínima, a la luz de las circunstancias atenuantes indicadas.

Por último, pone de manifiesto que no dispone todavía de la traducción al castellano de los Documentos 5 y 6, por lo que anuncia que aportará dichas traducciones tan pronto como disponga de ellas y que está elaborando un documento adicional con el proceso seguido en los canales digitales identificados en la tabla que se ha aportado como Documento 7, relativo a la implementación del segundo factor de autenticación en los canales digitales de otros comercios líderes en España, por lo que anuncia que aportará dicho documento adicional tan pronto como disponga del mismo.

SÉPTIMO: En fecha 17 de junio de 2024, al no constar recibida parte de la documentación que anunciaba que aportaría, se le requiere para que, en un plazo de 5 días la aporte, con indicación de que, en caso de no aportarse dicha documentación,

se proseguirá con la tramitación del procedimiento, conforme a lo dispuesto en el artículo 77 de la LPACAP.

En cumplimiento del requerimiento, en fecha 25 de junio de 2024, procede a presentar Documento 7 bis, que contiene muestreo de proceso seguido en algunos de los canales digitales identificados en la tabla que fue aportada como Documento 7, así como las traducciones al castellano de los Documentos 5 y 6, como Documento 5bis y Documento 6bis.

OCTAVO: En fecha 16 de octubre de 2024, la instructora del procedimiento acordó abrir periodo de práctica de pruebas por un plazo de 20 (veinte) días, a contar desde el día siguiente a aquel en el que tuviera lugar la notificación del acto, según lo dispuesto en el artículo 77 y 78 de la LPACAP, teniéndose por reproducidos, a efectos probatorios, la documentación aportada por Carrefour, así como los documentos obtenidos y generados por la Subdirección General de Inspección de Datos, el informe de actuaciones previas de investigación que forman parte del procedimiento AI/00154/2023, las alegaciones al acuerdo de inicio del procedimiento sancionador presentadas por Carrefour y la documentación que a ellas acompañaba.

Asimismo, se acordó requerir a Carrefour para que, en un plazo de 10 días hábiles, computados desde la aceptación de la notificación de dicho escrito, aportara la información y/o documentación siguiente:

- Política de contraseñas en la que figuren las medidas implantadas y la fecha de su implementación.
- Número de cuentas, de las 1.741 ya comprometidas en la tercera brecha de datos personales, a las que el tercero tuvo acceso en la cuarta brecha de datos personales.
- Informes de las pruebas de penetración (Pentest) realizadas por Carrefour en 2022, en la web Ecommerce carrefour.es y en la APP Carrefour.
- Fecha de implantación de las medidas recomendadas en los informes de las pruebas de penetración (Pentest) realizadas en la web y en la APP Carrefour, finalizadas el 3/03/2023 y 9/02/2023, respectivamente.
- Número total de peticiones de acceso realizadas por el atacante contra la web y la APP de Carrefour para cada una de las cinco brechas de datos personales, incluidas las peticiones a cuentas de Carrefour que no dieron como resultado "OK".

NOVENO: En fecha 24 de octubre de 2024, en contestación al escrito en el que solicitaba la ampliación del plazo que le fue concedido, en virtud de lo establecido en el artículo 32.1 de la LPACAP, se acordó ampliar el plazo hasta un máximo de cinco días, que debían computarse a partir del día siguiente a aquel en el que finalizara el primer plazo.

DÉCIMO: En fecha 31 de octubre de 2024, en contestación al escrito presentado, se remitió la copia del expediente solicitada de acuerdo con lo dispuesto en el art. 53.1 a) de la LPACAP.

UNDÉCIMO: En fecha 8 de noviembre de 2024, CCC presentó escrito de contestación al requerimiento de información, en el que pone de manifiesto lo siguiente:

1. Política de contraseñas en la que figuren las medidas implantadas y la fecha de su implementación.

La política de contraseñas de CCC actualmente vigente se implementó en junio de 2022. Según dicha política, para que una contraseña sea válida, debe reunir las siguientes características:

(...)

Aporta como Documento 1 la ficha de desarrollo de la política de contraseñas modificada en junio de 2022 y una captura de pantalla con las características que deben reunir las contraseñas para que sean válidas.

2. Número de cuentas, de las 1.741 ya comprometidas en la tercera brecha de datos personales, a las que el tercero tuvo acceso en la cuarta brecha de datos personales.

En la Tercera Brecha (la notificada el 21 de abril de 2023) hubo 61.083 peticiones de acceso satisfactorias (resultado "OK") y en la Cuarta Brecha (la notificada el 26 de junio de 2023) hubo 10.943. El número de cuentas coincidentes en las dos brechas – esto es, para las que la consulta del tercero resultó en un "OK"- fue de 1.741.

3. Informes de las pruebas de penetración (Pentest) realizadas por Carrefour en 2022, en la web Ecommerce Carrefour.es y en la APP Carrefour.

Aporta como Documento 2 el Informe.

Pone de manifiesto que las vulnerabilidades identificadas en el pentest (ninguna de severidad crítica o alta) se detectaron como consecuencia de facilitar información al auditor sobre la infraestructura de los sistemas de CCC y de la desactivación de medidas de seguridad para permitir la realización de la auditoría.

4. Fecha de implantación de las medidas recomendadas en los informes de las pruebas de penetración (Pentest) realizadas en la web y en la APP Carrefour, finalizadas el 3/03/2023 y el 9/02/2023, respectivamente.

En relación con el pentest para la aplicación (28 de febrero de 2023):

Se incluyeron un total de 10 recomendaciones, listadas en los siguientes apartados del pentest: 5.1.4, 6.1.4, 6.2.4, 6.3.4, 6.4.4, 7.1.4, 7.2.4, 7.3.4, 7.4.4 y 7.5.4.

De estas 10 recomendaciones:

a) Una de ellas (la 5.1.4, correspondiente a una vulnerabilidad de severidad alta) fue implementada el 13 de febrero de 2023, tal y como se pone de manifiesto en el propio pentest:

5.1 Referencia Insegura a objetos (IDOR) (CORREGIDA)

b) Cuatro de ellas (las 6.1.4, 6.2.4, la 7.1.4 y la 7.2.4, todas ellas correspondientes a vulnerabilidades de severidad media) no resultan de aplicación, en la medida en que son recomendaciones derivadas de vulnerabilidades que fueron detectadas como consecuencia de facilitar información al auditor sobre la infraestructura de los sistemas de CCC y de la eliminación de medidas de seguridad para facilitar el trabajo del auditor en el pentest en modalidad de caja gris.

c) Las cinco restantes (la 6.3.4, 6.4.4, 7.3.4, 7.4.4 y 7.5.4, todas ellas correspondientes a vulnerabilidades de severidad baja) fueron asumidas, esto es, no se implementaron en la medida en que en estas vulnerabilidades el vector de ataque era local o físico, por lo que el riesgo es bajo y muy reducido, en particular en los vectores de ataque físicos, en los que el atacante necesita interactuar físicamente con el dispositivo del cliente.

d) En cualquier caso, ninguna de las 10 recomendaciones tiene incidencia en las brechas sobre las que versa el acuerdo de inicio del procedimiento sancionador.

En relación con el pentest para la web (6 de marzo de 2023):

Se incluyeron un total de 19 recomendaciones, listadas en los siguientes apartados del pentest: 5.1.4, 5.2.4, 5.3.4, 5.4.4, 5.5.4, 5.6.4, 5.7.4, 5.8.4, 5.9.4, 5.10.4, 5.11.4, 5.12.4, 5.13.4, 5.14.4, 5.15.4, 5.16.4, 5.17.4, 5.18.4 y 5.19.4.

De estas 19 recomendaciones:

a) Cuatro de ellas fueron implementadas en las siguientes fechas:

- La 5.1.4 (correspondiente a una vulnerabilidad de severidad crítica) fue implementada el 11 de julio de 2023. Aportamos documentación justificativa de la implementación de la recomendación como Documento 3.
- La 5.6.4 (correspondiente a una vulnerabilidad de severidad media) fue implementada en septiembre de 2024.
- La 5.9.4 (correspondiente a una vulnerabilidad de severidad media) fue implementada en septiembre de 2024.
- La 5.17.4 (correspondiente a una vulnerabilidad de severidad baja) fue implementada en septiembre de 2024.

Aporta como Documento 4 la justificación documental de la implementación de las recomendaciones 5.6.4, 5.9.4 y 5.17.4. Como puede observarse en el apartado "Configuración" (Configuration), CCC no utiliza conjuntos de cifrado (cipher suites) RC4 (recomendación 5.6.4), triple-DES y cifrados de bloque de 64 bits (recomendación 5.9.4) y tipo CBC (recomendación 5.17.4).

b) Una de ellas (la 5.2.4, correspondiente a una vulnerabilidad de severidad alta) no pudo ser reproducida por el auditor y fue finalmente marcada como corregida, tal y como se observa en la captura de pantalla que aporta como Documento 5.

c) Tres de ellas (las 5.5.4, 5.7.4 y la 5.8.4; todas ellas correspondientes a vulnerabilidades de severidad media) no resultan de aplicación, en la medida en que son recomendaciones derivadas de vulnerabilidades que fueron detectadas como consecuencia de facilitar información al auditor sobre la infraestructura de los sistemas de CCC y de la eliminación de medidas de seguridad para facilitar el trabajo del auditor en el pentest en modalidad de caja gris.

d) Dos de ellas (las 5.3.4 y 5.4.4; ambas correspondientes a vulnerabilidades de severidad media) no fueron implementadas, en la medida en que las correspondientes vulnerabilidades no pueden ser explotadas por la existencia de otras medidas de seguridad (en ambos casos, el uso de firewalls de aplicaciones web) aplicadas por CCC. De hecho, en la 5.3 el auditor admite que no ha sido posible "comprobar la explotación de esta vulnerabilidad" y que su existencia de notificar a los efectos de "solicitar su mitigación en caso necesario".

e) Las nueve restantes (las 5.10.4, 5.11.4, 5.12.4, 5.13.4, 5.14.4, 5.15.4, 5.16.4, 5.18.4 y 5.19.4; las tres primeras correspondientes a vulnerabilidades de severidad media y las seis restantes a vulnerabilidades de severidad baja) fueron asumidas, esto es, no se implementaron en la medida en que las vulnerabilidades – y las consiguientes recomendaciones – no superaban el umbral de materialidad.

f) En cualquier caso, ninguna de las 19 recomendaciones tiene incidencia en las brechas sobre las que versa el acuerdo de inicio de procedimiento sancionador.

5. Número total de peticiones de acceso realizadas por el atacante contra la web y la APP de Carrefour para cada una de las cinco brechas de datos personales, incluidas las peticiones a cuentas de Carrefour que no dieron como resultado "OK".

CCC no conserva el número de las peticiones no satisfactorias de las cinco brechas.

No obstante, los números de peticiones satisfactorias para cada brecha son los siguientes:

Brecha	Peticiones de acceso satisfactorias
Primera Brecha	(...)
Segunda Brecha	(...)
Tercera Brecha	(...)
Cuarta Brecha	(...)
Quinta Brecha	(...)

DUODÉCIMO: En fecha 5 de diciembre de 2024, se formuló propuesta de resolución, proponiendo:

<<. Que por la Directora de la Agencia Española de Protección de Datos se sancione a CENTROS COMERCIALES CARREFOUR, S.A., con NIF A28425270,

- por la infracción del artículo 5.1.f) del RGPD, tipificada conforme a lo dispuesto en el artículo 83.5 del RGPD, calificada como muy grave a efectos de prescripción, en el artículo 72.1 a) de la LOPDGDD, con una multa de 2.000.000 euros.

- por la infracción del artículo 32 del RGPD, tipificada conforme a lo dispuesto en el artículo 83.4 del RGPD, calificada como grave a efectos de prescripción, en el artículo 73 f) de la LOPDGDD, con una multa de 1.000.000 euros.

- por la infracción del artículo 34) del RGPD, tipificada conforme a lo dispuesto en el artículo 83.4 del RGPD, calificada como leve a efectos de prescripción, en el artículo 74 ñ) de la LOPDGDD, con una multa de 200.000 euros.

Que por la Directora de la Agencia Española de Protección de Datos se ordene a CENTROS COMERCIALES CARREFOUR, S.A., con NIF A28425270, que en virtud del artículo 58.2.d) del RGPD, en el plazo de un mes, acredite haber procedido al cumplimiento de la siguiente medida: la comunicación de las brechas de datos personales a los afectados cuyos datos se hayan visto afectados en los términos y condiciones previstos por el artículo 34 del RGPD.>>

La citada propuesta de resolución fue enviada, conforme a las normas establecidas en la LPACAP, mediante notificación electrónica, siendo recibida en fecha 10 de diciembre de 2024, como consta en el certificado que obra en el expediente.

DECIMOTERCERO: La entidad investigada no ha presentado alegaciones a la Propuesta de Resolución.

A la vista de todo lo actuado, por parte de la Agencia Española de Protección de Datos, en el presente procedimiento, se consideran hechos probados los siguientes,

HECHOS PROBADOS

PRIMERO: Notificaciones de brechas de datos personales:

Carrefour ha notificado hasta cinco violaciones de seguridad de los datos personales, todas ellas relacionadas con el acceso ilegítimo a cuentas de clientes por parte de terceros no autorizados, haciéndose uso con una alta probabilidad de la técnica de ataque de Credential Stuffing utilizando credenciales filtradas (pares de email/contraseña), careciéndose de evidencias que muestren ataque de fuerza bruta.

Primera violación de la seguridad de los datos personales

En el Informe de actuaciones previas de investigación consta la siguiente información:

(...)

Segunda violación de la seguridad de los datos personales:

En el Informe de actuaciones previas de investigación consta la siguiente información:

(...)

Tercera violación de la seguridad de los datos personales

En el Informe de actuaciones previas de investigación consta la siguiente información:

(...)

Cuarta violación de la seguridad de los datos personales:

(...)

Quinta violación de la seguridad de los datos personales:

En el Informe de actuaciones previas de investigación consta la siguiente información:

(...)

SEGUNDO: (...), en fecha 7 de julio de 2023, se incluye por la propia entidad investigada en contestación al requerimiento efectuado por el inspector, un listado de datos personales a los que se pudo tener acceso, organizados por tipología de datos:

- o *Nombre, Apellido 1, Apellido 2*
- o *Correo Electrónico*
- o *Teléfono de contacto (enmascarado con asteriscos todos los dígitos exceptuando los 3 últimos)*
- o *DNI (enmascarado con asteriscos todos los caracteres exceptuando los 4 últimos)*
- o *Dirección postal completa: Código postal, Escalera/piso/puerta, Municipio, Nombre de la vía, Número de la vía, Provincia, Tipo de vía, Fecha de nacimiento.*

Asimismo, consta en la notificación de la tercera brecha de seguridad de los datos personales, que se produjo el 18 de abril de 2023, que el atacante tuvo acceso a Datos básicos (Ej: nombre, apellidos, fecha de nacimiento), DNI, NIE, Pasaporte y / o cualquier otro documento identificativo, Datos económicos o financieros (sin medios de pago), Datos de contacto, Credenciales de acceso o identificación (usuario y / o contraseña).

En la notificación de la cuarta brecha de datos personales, ocurrida el 23 de junio 2023, consta que el atacante accedió a datos básicos (Ej: nombre, apellidos, fecha de nacimiento), Datos de contacto, Credenciales de acceso o identificación (usuario y / o contraseña).

En la notificación de la quinta brecha de datos personales ocurrida el 11 de septiembre de 2023 consta que el atacante tuvo acceso a datos básicos (Ej: nombre, apellidos, fecha de nacimiento), DNI, NIE, Pasaporte y / o cualquier otro documento identificativo, Datos de contacto, Credenciales de acceso o identificación (usuario y / o contraseña).

TERCERO: En relación con la posible insuficiencia de medidas de seguridad existentes, (...).

CUARTO: Carrefour ha aportado la Evaluación de Impacto en la Protección de Datos (DPIA) para la actividad de tratamiento afectada por la brecha ("*Cientes Club Carrefour*") de fecha de creación 14 de abril de 2021 y fecha de finalización 19 de julio de 2022.

Consta que dicho documento analiza las distintas bases jurídicas del tratamiento y utiliza el contrato como base legítima del tratamiento (hacen referencia a la aceptación de las Bases Legales de *El Club* y *My Account* como la firma de un contrato para el tratamiento de los datos personales del interesado).

Por otra parte, utilizan también otras bases legítimas distintas para las siguientes finalidades:

- Interés legítimo: *Para la verificación previa contra las bases de datos de CC CARREFOUR, gestión de la publicidad, lograr la centralización de las operaciones de tratamiento de los clientes, Desarrollo de procesos y canales de venta, analítica de comportamiento y revisión de operaciones sospechosas, prevención del fraude.*
- Consentimiento expreso: (i) *envío de publicidad por Carrefour sobre productos de entidades colaboradoras y Entidades Adscritas Grupo y no Grupo (Iberdrola, Cepsa etc.)* (ii) *cesión de datos personales a Entidades adscritas del Grupo Carrefour para publicidad propia de estas entidades.*

Se afirma que este tratamiento realiza perfilado, pero sin efectos jurídicos para los interesados: *Sin perjuicio de que se realicen evaluaciones sistemáticas de los clientes, no tienen efectos jurídicos sobre los mismos, sólo tiene impacto en el tipo de publicidad que reciben los socios club.*

Se realiza una descripción del tratamiento y el flujo de los datos, detallándose cada uno de los activos que intervienen en las distintas fases de recogida, almacenamiento y destino de los datos personales tratados.

Se realiza análisis y gestión de riesgos, destacando:

- Se analiza el factor de riesgo *robo de identidad que suponga riesgo financiero o de privacidad*, asignándole un valor de riesgo inherente de *Alto Impacto* y valor de riesgo residual de *Medio Impacto*.
- Se analiza el *riesgo financiero* para los sujetos involucrados en el tratamiento, asignándose inicialmente un valor de riesgo inherente *Muy Alto* y un valor de riesgo residual *Bajo*
- Se analiza los riesgos de pérdida de confidencialidad, asignando un valor de riesgo inherente *Alto Impacto* y riesgo residual *Bajo*.
- Entre las medidas de seguridad se mencionan para gestionar los riesgos aportan:

(...)

Asimismo, se incluye documento anexo a la DPIA que incorpora un listado de proyectos de seguridad en curso de desarrollo a lo largo del año 2023 con objeto de reforzar la seguridad. Del análisis de este documento se extrae:

(...)

El informe concluye con las siguientes recomendaciones y acciones a realizar:

(...)

(ii) Informe del Pentest a la APP Carrefour para Android/iOS, realizado con fecha de inicio 6 de febrero de 2023 y fecha de fin 9 de febrero de 2023.

De su análisis se extrae:

En cuanto a la metodología (punto 3 del informe) (...).

- Se detecta una vulnerabilidad nivel alto (aunque se afirma en el mismo informe que ha sido corregida), 5 de nivel medio y 5 nivel bajo.
- El informe concluye las siguientes recomendaciones sobre acciones a realizar:

(...)

SEXTO: En el presente caso, ha quedado constatado el envío por Carrefour de un comunicado, en fecha 23 de junio de 2023, a 9.202 afectados, correspondientes a la cuarta brecha de datos personales, y en fecha 11 de septiembre de 2023, a 10.959 afectados, correspondientes a la quinta brecha de seguridad de los datos personales.

De las actuaciones de investigación desarrolladas por la presente autoridad, la propia entidad investigada afirma que procedió a la comunicación por medio de correo electrónico, así como a través del canal push en los casos de clientes disponibles por este medio y siendo el contenido del mensaje enviado el siguiente:

“Estimado cliente:

Para ofrecerte un mejor servicio, hemos procedido a resetear tu contraseña. Para obtener una nueva solicítala en ¿has olvidado tu contraseña? al acceder a la App o a la web.

En la web

<https://www.carrefour.es/myaccount>

En la App

Identifícate y pulsa en ¿Has olvidado tu contraseña?

Un saludo

El equipo de Carrefour”

No consta que Carrefour comunicara a los afectados de la primera, segunda y tercera brecha de datos personales, en los términos indicados en el artículo 34 del RGPD, si bien esta posible infracción por la falta de comunicación a los afectados de la primera, segunda y tercera brecha de datos personales ha de considerarse prescrita.

SÉPTIMO: La política de contraseñas de CCC actualmente vigente se implementó en junio de 2022. Según dicha política, para que una contraseña sea válida, debe reunir las siguientes características:

- (...)

Aporta como Documento 1 la ficha de desarrollo de la política de contraseñas modificada en junio de 2022 y una captura de pantalla con las características que deben reunir las contraseñas para que sean válidas.

OCTAVO: En la Tercera Brecha (la notificada el 21 de abril de 2023) hubo 61.083 peticiones de acceso satisfactorias (resultado "OK") y en la Cuarta Brecha (la notificada el 26 de junio de 2023) hubo 10.943. El número de cuentas coincidentes en las dos brechas – esto es, para las que la consulta del tercero resultó en un "OK"- fue de 1.741.

NOVENO: Carrefour ha aportado Informe de la prueba de penetración (Pentest) realizada en 2022, denominado "*****INFORME.1**"

-
En cuanto a la severidad de las ocurrencias se indica en el informe:

Alta	Media	Baja
0	6	3

Asimismo, constan en el resumen Ejecutivo del informe las siguientes recomendaciones:

- A corto plazo:

(...)

- A medio plazo:

(...).

- A largo plazo:

(...)

DÉCIMO: Fecha de implantación de las medidas recomendadas en los informes de las pruebas de penetración (Pentest) realizadas en la web y en la APP Carrefour, finalizadas el 3/03/2023 y el 9/02/2023, respectivamente.

En relación con el pentest para la aplicación (28 de febrero de 2023):

Se incluyeron un total de 10 recomendaciones, listadas en los siguientes apartados del pentest: 5.1.4, 6.1.4, 6.2.4, 6.3.4, 6.4.4, 7.1.4, 7.2.4, 7.3.4, 7.4.4 y 7.5.4.

De estas 10 recomendaciones:

a) Una de ellas (la 5.1.4, correspondiente a una vulnerabilidad de severidad alta) fue implementada el 13 de febrero de 2023, tal y como se pone de manifiesto en el propio pentest:

5.1 Referencia Insegura a objetos (IDOR) (CORREGIDA)

b) Cuatro de ellas (las 6.1.4, 6.2.4, la 7.1.4 y la 7.2.4, todas ellas correspondientes a vulnerabilidades de severidad media) no resultan de aplicación, en la medida en que son recomendaciones derivadas de vulnerabilidades que fueron detectadas como consecuencia de facilitar información al auditor sobre la infraestructura de los sistemas de CCC y de la eliminación de medidas de seguridad para facilitar el trabajo del auditor en el pentest en modalidad de caja gris.

c) Las cinco restantes (la 6.3.4, 6.4.4, 7.3.4, 7.4.4 y 7.5.4, todas ellas correspondientes a vulnerabilidades de severidad baja) fueron asumidas, esto es, no se implementaron en la medida en que en estas vulnerabilidades el vector de ataque era local o físico, por lo que el riesgo es bajo y muy reducido, en particular en los vectores de ataque físicos, en los que el atacante necesita interactuar físicamente con el dispositivo del cliente.

d) En cualquier caso, ninguna de las 10 recomendaciones tiene incidencia en las brechas sobre las que versa el acuerdo de inicio del procedimiento sancionador.

En relación con el pentest para la web (6 de marzo de 2023):

Se incluyeron un total de 19 recomendaciones, listadas en los siguientes apartados del pentest: 5.1.4, 5.2.4, 5.3.4, 5.4.4, 5.5.4, 5.6.4, 5.7.4, 5.8.4, 5.9.4, 5.10.4, 5.11.4, 5.12.4, 5.13.4, 5.14.4, 5.15.4, 5.16.4, 5.17.4, 5.18.4 y 5.19.4.

De estas 19 recomendaciones:

a) Cuatro de ellas fueron implementadas en las siguientes fechas:

- La 5.1.4 (correspondiente a una vulnerabilidad de severidad crítica) fue implementada el 11 de julio de 2023. Aportamos documentación justificativa de la implementación de la recomendación como Documento 3.
- La 5.6.4 (correspondiente a una vulnerabilidad de severidad media) fue implementada en septiembre de 2024.
- La 5.9.4 (correspondiente a una vulnerabilidad de severidad media) fue implementada en septiembre de 2024.
- La 5.17.4 (correspondiente a una vulnerabilidad de severidad baja) fue implementada en septiembre de 2024.

Aporta como Documento 4 la justificación documental de la implementación de las recomendaciones 5.6.4, 5.9.4 y 5.17.4. Como puede observarse en el apartado "Configuración" (Configuration), CCC no utiliza conjuntos de cifrado (cipher suites) RC4 (recomendación 5.6.4), triple-DES y cifrados de bloque de 64 bits (recomendación 5.9.4) y tipo CBC (recomendación 5.17.4).

b) Una de ellas (la 5.2.4, correspondiente a una vulnerabilidad de severidad alta) no pudo ser reproducida por el auditor y fue finalmente marcada como corregida, tal y como se observa en la captura de pantalla que aporta como Documento 5.

c) Tres de ellas (las 5.5.4, 5.7.4 y la 5.8.4; todas ellas correspondientes a vulnerabilidades de severidad media) no resultan de aplicación, en la medida en que son recomendaciones derivadas de vulnerabilidades que fueron detectadas como consecuencia de facilitar información al auditor sobre la infraestructura de los sistemas de CCC y de la eliminación de medidas de seguridad para facilitar el trabajo del auditor en el pentest en modalidad de caja gris.

d) Dos de ellas (las 5.3.4 y 5.4.4; ambas correspondientes a vulnerabilidades de severidad media) no fueron implementadas, en la medida en que las correspondientes vulnerabilidades no pueden ser explotadas por la existencia de otras medidas de seguridad (en ambos casos, el uso de firewalls de aplicaciones web) aplicadas por CCC. De hecho, en la 5.3 el auditor admite que no ha sido posible "comprobar la explotación de esta vulnerabilidad" y que su existencia de notificar a los efectos de "solicitar su mitigación en caso necesario".

e) Las nueve restantes (las 5.10.4, 5.11.4, 5.12.4, 5.13.4, 5.14.4, 5.15.4, 5.16.4, 5.18.4 y 5.19.4; las tres primeras correspondientes a vulnerabilidades de severidad media y las seis restantes a vulnerabilidades de severidad baja) no fueron asumidas, esto es, no se implementaron en la medida en que las vulnerabilidades – y las consiguientes recomendaciones – no superaban el umbral de materialidad.

f) En cualquier caso, ninguna de las 19 recomendaciones tiene incidencia en las brechas sobre las que versa el acuerdo de inicio de procedimiento sancionador.

UNDÉCIMO: CCC no conserva el número de las peticiones no satisfactorias de las cinco brechas.

No obstante, los números de peticiones satisfactorias para cada brecha son los siguientes:

Brecha	Peticiones de acceso satisfactorias
<u>Primera Brecha</u>	<u>(...)</u>
<u>Segunda Brecha</u>	<u>(...)</u>
<u>Tercera Brecha</u>	<u>(...)</u>
<u>Cuarta Brecha</u>	<u>(...)</u>
<u>Quinta Brecha</u>	<u>(...)</u>

FUNDAMENTOS DE DERECHO

I Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la LOPDGDD, es competente para resolver este procedimiento, la Presidencia de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II

Cuestiones Previas

La sociedad anónima Centros Comerciales Carrefour es una compañía dedicada a la explotación tanto de grandes superficies como de establecimientos situados en ellas y, en concreto, está especializada en la comercialización en establecimientos no especializados, con predominio de alimentos y bebidas, prestando además servicios de comercio electrónico, para lo cual trata datos de carácter personal de sus clientes y trabajadores, entendiéndose por dato de carácter personal: *"toda información sobre una persona física identificada o identificable"*.

Realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del artículo 4.7 del RGPD:

«responsable del tratamiento» o «responsable»: la persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento; si el Derecho de la Unión o de los Estados miembros determina los fines y medios del tratamiento, el responsable del tratamiento o los criterios específicos para su nombramiento podrá establecerlos el Derecho de la Unión o de los Estados miembros

Se considera persona física identificable aquella cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona.

Asimismo, debe entenderse por tratamiento *"cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no, como la recogida, registro, organización, estructuración, conservación, adaptación o modificación, extracción, consulta, utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo o interconexión, limitación, supresión o destrucción"*.

El artículo 4 apartado 12 del RGPD define, de un modo amplio, las *"violaciones de seguridad de los datos personales"* como *"todas aquellas violaciones de la seguridad que ocasionen la destrucción, pérdida o alteración accidental o ilícita de datos"*

personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.”

En el presente caso, se han notificado hasta cinco brechas de datos personales por parte del responsable de tratamiento CARREFOUR, todas ellas relacionadas con el acceso ilegítimo a cuentas de clientes por parte de terceros no autorizados, haciéndose uso, al menos en cuatro de ellas, con una alta probabilidad de la técnica de ataque de Credential Stuffing, utilizando credenciales filtradas (pares de email/contraseña), careciéndose de evidencias que muestren ataque de fuerza bruta.

En el transcurso de las actuaciones de investigación realizadas se ha puesto de manifiesto que las brechas de datos personales segunda, tercera, cuarta y quinta, notificadas en fechas 20 de enero de 2023, 18 de abril de 2023, 26 de junio de 2023 y 14 de septiembre de 2023, guardan la misma tipología (*Credential Stuffing*), utilizándose métodos automatizados que hacían uso de direcciones de correo ordenadas en orden alfabético, lo que indicaba que el atacante utilizaba algún tipo de base de datos como diccionario para lanzar sus ataques. Los ataques se realizaron en un corto periodo de tiempo y desde múltiples direcciones IP, lo cual, según ha manifestado CARREFOUR, dificultó su identificación y poder pararlo en tiempo de ejecución.

En cuanto a la posible fuente u origen de las credenciales que los atacantes podrían haber utilizado para llevar a cabo el ataque *Credential Stuffing*, en su escrito de 20 de enero de 2023, CARREFOUR informó que se descubrió el 17 de enero de 2023 que se ofrecían credenciales para algunas direcciones email afectadas en un grupo de ***APP.1. Asimismo, informó en su escrito de 7 de julio de 2023 que se descubrió que actualmente se ofertan paquetes de credenciales expuestas de varias organizaciones, entre ellas Carrefour España, en diferentes sitios de la Dark Web, si bien afirman que todos los intentos de localizar la fuente original de estos datos por parte de CARREFOUR han sido infructuosos, debido a la alta complejidad de localizar dichos sitios.

En cuanto a la tipología de datos personales a los que se pudo tener acceso el atacante en la segunda violación de la seguridad de los datos personales, Carrefour ha informado que, una vez implantadas las medidas reactivas tras la primera brecha detectada en enero de 2023, son:

- o *Nombre, Apellido 1, Apellido 2*
- o *Correo Electrónico*
- o *Teléfono de contacto (enmascarado con asteriscos todos los dígitos exceptuando los 3 últimos)*
- o *DNI (enmascarado con asteriscos todos los caracteres exceptuando los 4 últimos)*
- o *Dirección postal completa: Código postal, Escalera/piso/puerta, Municipio, Nombre de la vía, Número de la vía, Provincia, Tipo de vía, Fecha de nacimiento.*

Asimismo, consta en la notificación de la tercera brecha de datos personales, que se produjo el 16 de abril de 2023, que el atacante tuvo acceso a Datos básicos (Ej: nombre, apellidos, fecha de nacimiento), DNI, NIE, Pasaporte y / o cualquier otro

documento identificativo, Datos económicos o financieros (sin medios de pago), Datos de contacto, Credenciales de acceso o identificación (usuario y / o contraseña).

En la notificación de la cuarta brecha de datos personales, ocurrida el 23 de junio 2023, consta que el atacante accedió a datos básicos (Ej: nombre, apellidos, fecha de nacimiento), Datos de contacto, Credenciales de acceso o identificación (usuario y / o contraseña).

En la notificación de la quinta brecha de datos personales, ocurrida el 11 de septiembre, de 2023 consta que el atacante tuvo acceso a datos básicos (Ej: nombre, apellidos, fecha de nacimiento), DNI, NIE, Pasaporte y / o cualquier otro documento identificativo, Datos de contacto, Credenciales de acceso o identificación (usuario y / o contraseña)

Dentro de los principios del tratamiento previstos en el artículo 5 del RGPD, la integridad y confidencialidad de los datos personales se garantiza en el apartado 1.f) del artículo 5 del RGPD.

Por su parte, la seguridad de los datos personales viene regulada en los artículos 32, 33 y 34 del RGPD, que reglamentan la seguridad del tratamiento, la notificación de una violación de la seguridad de los datos personales a la autoridad de control y la comunicación de una violación de la seguridad de los datos personales al interesado, respectivamente.

En relación con la infracción del artículo 33 del RGPD, tipificada en el artículo 83.4 del citado Reglamento, consta que la entidad investigada sufrió una brecha de seguridad de los datos personales de la que tuvo constancia el 6 de octubre de 2022, si bien no lo notificó a esta Agencia hasta el 13 de enero de 2023, sin haber acreditado los motivos que justifiquen tal dilación. No obstante, como quiera que la LOPDGDD establece un plazo de prescripción de un año en su artículo 74 m) para estas infracciones, se ofrece adecuado su no imputación.

III

Respuesta a las alegaciones al acuerdo de inicio

En relación con las alegaciones aducidas al acuerdo de inicio del presente procedimiento sancionador, se procede a dar respuesta a las mismas según el orden expuesto por CCC:

ALEGACIÓN PRIMERA. Aclaraciones previas sobre los incidentes de seguridad sufridos por CCC

Manifiesta Carrefour que el número de cuentas afectadas informado a la Agencia en cada una de las notificaciones de brechas de seguridad de los datos personales se corresponde con el número de cuentas respecto de las que el tercero obtuvo confirmación de la validez de las credenciales de acceso, pero que no se trata de cuentas a las que el tercero hubiera tenido acceso.

A este respecto, procede señalar que, en la notificación de quiebra de la seguridad de los datos personales realizada por Carrefour, el 13/01/2023, consta que en el incidente de 06/10/2022 se vieron comprometidos los datos de 234 clientes; en la notificación,

de 20/01/2023, consta que en el incidente de 18/01/2023 los clientes comprometidos fueron 35.735; en la notificación de 18/04/2023 constan 61.083 clientes afectados en el incidente de 16/04/2023; en la notificación de 26/06/2023 consta un total de 10.943 clientes afectados en el incidente de 23/06/2023 y, finalmente, en la notificación, de 13/09/2023, consta que los clientes afectados fueron 10.900, en el incidente 11/09/2023.

Brecha	<u>Peticiones de acceso satisfactorias</u>
Primera Brecha	(...)
Segunda Brecha	(...)
Tercera Brecha	(...)
Cuarta Brecha	(...)
Quinta Brecha	(...)

Por tanto, pese a la argumentación de Carrefour, esta AEPD considera que las brechas de datos personales comunicadas por Carrefour afectaron a un total de 118.895 cuentas únicas. En 118.895 cuentas el atacante obtuvo una autenticación exitosa, por lo que conoció que las credenciales de acceso a esas cuentas eran correctas y consiguió accesos exitosos a estas. Por tanto, tuvo acceso a información personal de los titulares de esas cuentas, al menos a las credenciales que utilizaban para logarse, lo que supuso un riesgo alto para los derechos y libertades de los interesados.

Recuérdese en este punto que el concepto de dato de carácter personal ha de interpretarse en un sentido amplio, comprendiendo no sólo los datos personales recabados y conservados por el responsable del tratamiento, sino toda la información resultante de dicho tratamiento (STJUE de 4 de mayo de 2023, en el asunto C-487/21) y que, por tanto, los datos de contraseña/usuario de los usuarios son datos de carácter personal.

Así las cosas, un total de 118.895 credenciales de acceso se vieron comprometidas en los ataques. La obtención de las credenciales constituye un grave riesgo para las personas que ven vulnerada su seguridad, pudiendo ser víctimas de suplantación, estafa o fraude, entre otros.

De este modo, desde el 06/10/2022 el tercero obtuvo confirmación de la validez de las credenciales de acceso, lo que como se ha dicho supuso un alto riesgo para los derechos y libertades de las personas. Las credenciales de Carrefour se vendían en un grupo de ***APP.1, en este sentido reconoce Carrefour que una vez el tercero ha confirmado la validez de las credenciales, procede a su venta por distintos canales: dark web, deep web, canales de ***APP.1, etcétera.

Es más, Carrefour afirma haber remitido un comunicado a tales afectados por la tercera brecha y, en fechas 23 de junio de 2023 y 11 de septiembre de 2023, a los afectados, correspondientes a la cuarta y quinta brecha de seguridad, respectivamente.

Si bien, en el comunicado no se advirtió a los afectados de forma clara que Carrefour había sufrido una brecha de la seguridad de los datos personales, por lo que no fueron conscientes de los riesgos a los que habían quedado expuestos.

ALEGACIÓN SEGUNDA. CCC no ha infringido el principio de integridad y confidencialidad.

En primer lugar, manifiesta que la afectación de la integridad y la confidencialidad de los datos personales de clientes de CCC se ha producido tan sólo en 973 casos.

Señala que el número de cuentas afectadas informado a la Agencia en cada una de las brechas de seguridad comunicadas se corresponde con el número de cuentas respecto de las que el tercero obtuvo confirmación de la validez de las credenciales, no se trata de cuentas a las que el tercero tuviera acceso, ni que haya tenido acceso a los datos personales de esos clientes

En relación con la integridad, afirma que los casos en los que la misma se vio afectada ascienden a 234 casos de clientes cuyos datos personales se vieran modificados. Los datos que se modificaron fueron la dirección de correo electrónico, la dirección de entrega, así como, en algunos casos, el número de teléfono y el nombre.

En relación con la confidencialidad, indica que los casos en los que la misma se vio afectada ascienden a 973. Este número se corresponde con los casos en los que se ha detectado un fraude en el cheque Ahorró de los clientes, que se reparten entre: los 234 casos de la Primera Brecha, donde la afectación de la confidencialidad también comportó una afectación de la integridad y 739 casos repartidos entre la Segunda y la Quinta Brecha.

Considera que la suma de las personas afectadas reportada en las brechas (118.895) no se corresponde con la totalidad de casos en los que la integridad y la confidencialidad se vieran afectadas, sino que la afectación de la integridad se limitó a 234 clientes y la afectación de la confidencialidad a 973.

A este respecto, procede señalar que las actuaciones de investigación desarrolladas por la presente autoridad han permitido constatar:

(...)

A este respecto, no puede defenderse de ninguna manera que no exista una infracción del artículo 5.1.f) RGPD, puesto que, al no haberse adoptado medidas adecuadas, se produjo un acceso ilegítimo a datos personales por un tercero no autorizado, lo que supuso la pérdida de confidencialidad, de integridad y de control de numerosos datos personales y que afectó a todos aquellos cuyos datos fueron conocidos, no sólo a aquellos clientes cuyos datos fueron luego suplantados. Ello supone el incumplimiento del deber de garantizar la confidencialidad e integridad de los datos personales, pues como se ha indicado, el artículo 5.1.f) señala que *deben ser tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito.*

Por tanto, el riesgo de pérdida de confidencialidad se ha materializado, lo que supone que los datos personales pueden ser utilizados para usos no conocidos (vendidos, comunicados, publicados, etc.), todo ello sin consentimiento de sus titulares, conllevando una pérdida total y absoluta de control sobre los mismos. Además, supone también un riesgo muy alto de uso fraudulento de los datos (usurpación de identidad, fraude, pérdidas financieras, etc.) o de que sirvan para cualquier otra utilidad que en determinadas circunstancias constituya una amenaza para sus titulares. Debe tenerse en cuenta además que la mayoría de los datos personales afectados son datos que no pueden ser modificados o cambiados por otros (nombre, apellidos)

Esta pérdida de control sobre los propios datos personales se traduce en una vulneración del derecho fundamental a la protección de datos reconocido en el artículo 18 de la Constitución Española pues tal y como ha indicado el Tribunal Constitucional (Sentencia 292/2000, de 30 de noviembre de 2000) *“el derecho fundamental a la protección de datos persigue garantizar a la persona un poder de control sobre sus datos personales, sobre su uso y destino, con el propósito de impedir su tráfico ilícito y lesivo para la dignidad y derecho del afectado (...) El derecho a la protección de datos garantiza a los individuos un poder de disposición sobre esos datos”*.

En el caso que nos ocupa, ha quedado acreditado que CCC ha vulnerado este deber de confidencialidad en relación con los datos personales que trata. Por tanto, no procede aceptar que deba reducirse la cuantía de la sanción teniendo en cuenta que, el número de afectados que han visto comprometida la integridad y/o confidencialidad de sus datos personales sea de 973, ya que la pérdida de control sobre los propios datos personales se produce desde el momento en que se materializa la brecha de datos personales, es decir, desde que se produce ese acceso por parte de un tercero no autorizado a los datos personales tratados por CCC. En cualquier caso, lo relevante para entender vulnerada la confidencialidad es que la información se encuentra totalmente a la libre disposición de terceros no autorizados.

Esta es la pérdida de confidencialidad que se le imputa y ahí es cuando se ha materializado la pérdida de control de los propios datos personales por los interesados.

En el caso que nos ocupa, por el tipo de datos que trata y que fueron afectados por las brechas y que CCC parece desdeñar, supone un riesgo alto, en caso de vulnerarse su confidencialidad, de ser usados de modo fraudulento: suplantación de la identidad phishing, fraude financiero, etc. Amén de tener en cuenta, además, en todo caso, que el riesgo de pérdida de confidencialidad ya se ha materializado al haberse producido el acceso no autorizado, con lo cual no es ya que exista “probabilidad” de riesgo de pérdida de confidencialidad y de control de las personas sobre sus datos personales, sino materialización de este riesgo que puede implicar a su vez un riesgo alto para los derechos y libertades de las personas que pueden sufrir usurpación de identidad o fraude o pérdidas financieras.

Por tanto, se significa que la vulneración de la confidencialidad que se imputa a CCC es la que le corresponde, es decir, por incumplir la obligación impuesta en el artículo 5.1.f) de tratar los datos de tal manera que se garantice una seguridad adecuada de los mismos, incluida la protección contra el tratamiento no autorizado o ilícito, mediante la aplicación de medidas técnicas u organizativas apropiadas.

Manifiesta CCC no estar de acuerdo en cuanto a las circunstancias agravantes tenidas en cuenta a la hora de determinar el cálculo de la sanción. Así:

- o La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido (artículo 83.2 a) del RGPD):

Entiende que debería reducirse la cuantía de la sanción teniendo en cuenta que, el número de afectados que han visto comprometida la integridad y/o confidencialidad de sus datos personales es de 973. Además, considera que, a pesar de que en estos casos se haya visto afectado un conjunto de datos (nombre y apellidos, dirección postal completa y fecha de nacimiento), los mismos no son críticos, máxime si tenemos en cuenta que, como se ha expuesto (Documento 2), el fin último perseguido por el tercero es cometer un fraude económico, siendo los datos personales afectados un medio para cometer dicho fraude, no un fin en sí mismo.

A este respecto, procede señalar que no procede admitir tales consideraciones como atenuante o como circunstancia que disminuya la gravedad de los hechos, más bien al contrario, pues precisamente por el elevado número de tratamientos que realiza y clientes que han resultado afectados, CCC está obligada a actuar con la especial diligencia que debe exigirse a una entidad de estas características, que realiza numerosos tratamientos de datos personales. Por último, no puede obviarse el número considerable de afectados de las brechas de datos personales. Las actuaciones de investigación desarrolladas han permitido constatar que el número de afectados que han visto comprometida la integridad y/o confidencialidad de sus datos personales es de 118.954, toda vez que se produjo un acceso ilegítimo a datos personales por un tercero no autorizado, lo que supuso la pérdida de confidencialidad y de control de numerosos datos personales y que afectó a todos aquellos cuyos datos fueron conocidos, no sólo a aquellos clientes cuyos datos fueron luego suplantados.

Procede recordar la Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006), que respecto de entidades cuya actividad lleva aparejado el continuo tratamiento de datos de clientes, indica “...el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las previsiones legales al respecto.”

En el caso que nos ocupa, el tipo de datos que trata y que fueron afectados por las brechas y que CCC parece desdeñar, supone un riesgo alto, en caso de vulnerarse su confidencialidad, de ser usados de modo fraudulento: suplantación de la identidad phishing, fraude financiero, etc.

- o La intencionalidad o negligencia en la infracción (artículo 83.2 b) del RGPD):

Entiende que la existencia de diligencia vendría avalada por la superación de la auditoría de *****EMPRESA.4** y aporta un informe de 2022 de la evaluación que se llevó a cabo de septiembre a octubre de 2022 de la seguridad de los sistemas de información de *****EMPRESA.5** (Documento 5), (...) (Documento 6), así como por el hecho de que el segundo factor de autenticación no fuera – ni sea – una práctica de mercado en los canales digitales de los comercios líderes españoles (Documento 7). Asimismo, también en relación con el doble factor de autenticación, vuelve a poner de manifiesto que la implementación de este se produjo antes del 30 de octubre de 2023. Para el canal app (hacia el que se dirigieron todos los ataques salvo el último) se implementó en marzo de 2023.

Sobre este particular se ha de señalar que el responsable del tratamiento debe implantar las medidas técnicas y organizativas teniendo en cuenta la naturaleza, el ámbito, el contexto y los fines del tratamiento, así como los riesgos de diversa probabilidad y gravedad para los derechos y libertades de las personas físicas (art. 24.1 RGPD). Por tanto, debe identificarse y evaluarse el riesgo para los derechos y libertades de las personas y aplicar las medidas teniendo en cuenta, entre otras circunstancias, el “contexto” en el que se han de definir y aplicar las medidas, que en este caso era el de una sucesión de quiebras de datos personales sufridas por CCC. La documentación aportada no refleja los nuevos riesgos para los derechos y libertades de las personas nacidos de las quiebras sufridas por Carrefour y, además, la existencia de estos acontecimientos es lo que diferencia a Carrefour de otros contextos en los que pudieran encontrarse otros canales digitales de otros comercios líderes españoles.

Por ello, que el segundo factor de autenticación no fuera – ni sea – una práctica de mercado en los canales digitales de los comercios líderes españoles no puede ser tomado en consideración en este caso. En materia de protección de datos, las medidas técnicas y organizativas a adoptar por los responsables del tratamiento y demás obligaciones a cumplir exigidas por el RGPD, deben ser las adecuadas en relación con los concretos riesgos que suponen los específicos tratamientos que realice cada responsable. Por tanto, al analizar la diligencia de unos y otros en el cumplimiento de la normativa ha de estarse a las circunstancias de cada caso, teniendo en cuenta la naturaleza, el alcance, el contexto y los fines de cada tratamiento, no existiendo, por tanto, casos idénticos.

A este respecto, procede recordar que no fue hasta después de la quinta brecha (en concreto el 30 de octubre de 2023) cuando se decide implantar el 2FA (con envío de clave OTP) para los inicios de sesión del canal digital Ecommerce. Disponer de esta medida con anterioridad hubiera evitado con gran probabilidad todos los ataques producidos en este canal, lo que demuestra una falta de diligencia por parte de CCC a la hora de implementar las medidas técnicas apropiadas para garantizar un nivel de seguridad adecuado al riesgo para los derechos y libertades de las personas. La implementación del Doble Factor de Autenticación (2FA) constituyó, sin duda, un avance significativo en la protección de la seguridad de los datos. Sin embargo, este avance llegó tardíamente, después de que se hubieran manifestado vulnerabilidades críticas y se produjeran hasta 5 brechas de datos personales con efectos amplios y con el mismo vector de entrada.

El hecho de que CCC sea una gran empresa para cuya actividad realiza un constante y abundante manejo de datos personales, realizando tratamientos que implican un

probable alto riesgo para los derechos y libertades de las personas físicas supone la exigencia de una diligencia mayor en el tratamiento de los datos personales que la que se pueda exigir a una pequeña empresa que realice tratamientos esporádicos o accesorios.

Además, CCC entiende que deberán tenerse en cuenta las siguientes circunstancias como atenuantes:

i. Cualquier otra medida tomada por el responsable del tratamiento para paliar los daños y perjuicios sufridos por los interesados (artículo 83.2 c) del RGPD).

Considera que debería ser tenida en cuenta como atenuante el hecho de que CCC tomara medidas para paliar los daños y perjuicios sufridos por los afectados. En este sentido: reseteó las credenciales que se habían visto afectadas; y en aquellos casos en los que se produjo un fraude en los chequesAhorro, CCC reembolsó el importe del chequeAhorro y emitió tarjetas regalo para las personas afectadas, de tal forma que, según aduce, éstas no sufrieron ningún impacto económico derivado del fraude.

Además, manifiesta que estas medidas fueron tomadas de forma espontánea, antes de que CCC tuviera constancia de los requerimientos de información y del inicio de la investigación de la Agencia.

A tal efecto debe señalarse que los efectos de la quiebra de los datos personales no sólo tuvieron efectos económicos, derivados del fraude en los chequesAhorro, sino que fue mucho más allá, pues la pérdida de confidencialidad de los datos personales implicó un mayor riesgo para los derechos y libertades de los afectados, incluso como se ha indicado sus credenciales se vendían en ***APP.1.

ii. El grado de cooperación con la autoridad de control con el fin deponer remedio a la infracción y mitigar los posibles efectos adversos de la infracción (artículo 83.2 f) del RGPD), así como la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable notificó la infracción y, en tal caso, en qué medida (artículo 83.2 h del RGPD).

CCC considera que es de aplicación esta atenuante en la medida en que el Acuerdo de Inicio se ha dictado como consecuencia de las cinco brechas de la seguridad de los datos personales comunicadas por CCC a la Agencia. Afirmo que debe valorarse como atenuante el que se hubiera notificado, cumpliendo de forma diligente con este deber. Se proporcionó información con total transparencia y por ello también entiende que deberían ser de aplicación estas circunstancias atenuantes. Finalmente, CCC ha cooperado de forma favorable con la investigación, proporcionando respuesta a todos los requerimientos efectuados.

A este respecto, procede señalar, en primer lugar, que el notificar a las autoridades de control y comunicar a los afectados la violación de la seguridad de los datos personales son obligaciones impuestas al responsable del tratamiento por el RGPD (artículos 33 y 34 respectivamente), es decir, su observancia viene impuesta por imperativo legal, se trata de un mandato que ha de ser cumplido, por lo que su incumplimiento por el responsable, de conformidad con lo requerido en dichos preceptos, puede suponer una infracción del RGPD.

En segundo lugar, los requerimientos de la AEPD son de obligado cumplimiento.

Por tanto, en este caso, el grado de cooperación con la Agencia no puede ser apreciado y no procede aplicar la atenuante, por cuanto la consideración de la cooperación con la Agencia como atenuante, tal y como pretende la entidad, no está ligada a ninguno de los supuestos en los que se encuentre prevista legalmente una colaboración o cooperación o dar respuesta a un requerimiento por mor de un mandato legal. Por tanto, cuando las actuaciones son debidas y obligadas por la Ley, como en el caso que nos ocupa, no procede su aplicación.

En consecuencia, las alegaciones deben ser desestimadas, significándose que las argumentaciones presentadas no desvirtúan el contenido esencial de las infracciones que imputan ni suponen causa de justificación o exculpación suficiente.

ALEGACIÓN TERCERA: CCC adoptó medidas de seguridad apropiadas.

(i) En cuanto a las medidas, indica CCC que sí adoptó medidas técnicas y organizativas adecuadas para evitar que la pérdida de la integridad y confidencialidad se volviera a producir y, en cualquier caso, para reducir eficazmente la probabilidad de materialización de la pérdida de integridad y confidencialidad de los datos personales de sus clientes, refiriendo en su escrito de alegaciones un listado de las mismas y afirmando que con ello cumple con lo exigido en el artículo 32 del RGPD.

Frente a ello, procede señalar que, de los hechos acaecidos, se deduce lo contrario.

CCC, a la hora de evaluar los riesgos de probabilidad y gravedad variables, debió tener en cuenta el riesgo para los derechos y libertades de las personas físicas y aplicar medidas técnicas y organizativas de seguridad apropiadas para garantizar un nivel de seguridad adecuado al riesgo. De seguridad. Sólo de seguridad.

Se imputa a CCC la infracción del citado artículo 32, con independencia de si se ha sufrido una brecha de confidencialidad o no, porque la conducta reprochable y que vulnera dicho precepto es la falta o inadecuación de las medidas de seguridad, es decir, se infringe y se sanciona por ello con independencia de si se ha producido una brecha de datos personales o no.

Del análisis de la documentación aportada por CCC en contestación al requerimiento de información resulta lo siguiente: “(…).”

Por tanto, existía una deficiencia en las medidas de seguridad implantadas, pues las medidas defectivas no eran adecuadas y ello con independencia de que se hubiera producido o no una brecha de datos personales ya que permitían accesos consecutivos desde más de 7.000 direcciones IP distintas de diferentes proveedores de red, sin que se detectaran comportamientos anómalos. Ello pone de manifiesto claramente un incumplimiento del artículo 32 del RGPD, por cuanto exige medidas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, y todo ello teniendo en cuenta el estado de la técnica, los costes de aplicación y la naturaleza, el alcance, el contexto y los fines del tratamiento.

A tal efecto, hay que acudir al considerando 83 del RGPD, el cual establece que

“A fin de mantener la seguridad y evitar que el tratamiento infrinja lo dispuesto en el presente Reglamento, el responsable o el encargado deben evaluar los riesgos inherentes al tratamiento y aplicar medidas para mitigarlos, como el cifrado. Estas medidas deben garantizar un nivel de seguridad adecuado, incluida la confidencialidad, teniendo en cuenta el estado de la técnica y el coste de su aplicación con respecto a los riesgos y la naturaleza de los datos personales que deban protegerse. Al evaluar el riesgo en relación con la seguridad de los datos, se deben tener en cuenta los riesgos que se derivan del tratamiento de los datos personales, como la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos, susceptibles en particular de ocasionar daños y perjuicios físicos, materiales o inmateriales.” (el subrayado es nuestro)

Por otro lado, el artículo 32 del RGPD indica que las medidas implantadas deben incluir la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento (letra b del artículo 32.1 RGPD). Por tanto, no basta con tener medidas para reaccionar lo antes posible cuando se ha vulnerado la confidencialidad, hay que tener también medidas previas adecuadas para impedir una vulneración como lo son las medidas preventivas y detectivas dirigidas a evitar cualquier pérdida de la confidencialidad, integridad y disponibilidad de los datos personales.

Las medidas de seguridad técnicas y organizativas que deben aplicarse son las pertinentes para responder al riesgo existente, valorando, entre otros factores, el estado de la técnica, los costes de aplicación, la naturaleza, alcance, contexto y finalidades del tratamiento y los riesgos de probabilidad y gravedad para los derechos y libertades de las personas interesadas.

En este sentido el artículo 32, no establece medidas de seguridad concretas y estáticas, sino que corresponderá al responsable determinar las medidas de seguridad que son necesarias en cada momento para garantizar la confidencialidad, la integridad y la disponibilidad de los datos personales. En consecuencia, la protección de unos mismos datos puede implicar medidas de seguridad distintas en función de las especificidades concretas de las distintas operaciones de tratamiento de datos.

La obligación de seguridad que impone al responsable del tratamiento el artículo 32 del RGPD es una obligación de medios, sin que se requiera para su infracción que se haya producido un resultado: la pérdida de confidencialidad, integridad o disponibilidad.

Como precisa la STS de 15/02/2022 (rec. de casación 7359/2020) *“En las obligaciones de medios el compromiso que se adquiere es el de adoptar los medios técnicos y organizativos, así como desplegar una actividad diligente en su implantación y utilización que tienda a conseguir el resultado esperado con medios que razonablemente puedan calificarse de idóneos y suficientes para su consecución, por ello se las denomina obligaciones “de diligencia” o “de comportamiento”.* (El subrayado es nuestro).

Resulta también relevante la STJUE, de 14/12/2023, asunto C-340/21, en la que el Tribunal señala lo siguiente:

“(...) el carácter apropiado de tales medidas técnicas y organizativas debe apreciarse de manera escalonada. Por una parte, es preciso identificar los riesgos de violación de la seguridad de los datos personales que entrañe el tratamiento y sus posibles consecuencias para los derechos y libertades de las personas físicas. Esta apreciación debe llevarse a cabo en cada caso concreto, tomando en consideración cuál es la probabilidad de los riesgos identificados y la gravedad de estos. Seguidamente, debe comprobarse si las medidas adoptadas por el responsable del tratamiento se adaptan a estos riesgos, teniendo en cuenta el estado de la técnica, el coste de la aplicación y la naturaleza, ámbito, contexto y fines del tratamiento”. (apartado 42).

En este caso las medidas implantadas por CCC no garantizaban un nivel adecuado al riesgo, por cuanto no tenían en cuenta los riesgos identificados y la gravedad de estos. CCC estaba sufriendo un episodio de sucesivas brechas de datos personales y no adoptó medidas adecuadas para mitigar el impacto en caso de ocurrencia de una brecha de datos personales. Y ello con independencia de que finalmente ésta se llegara a producir o no.

Pues bien, ya en la auditoría realizada al canal web (www.carrefour.es) entre el 14 de febrero de 2023 y 3 de marzo de 2023, consta en el punto 5.11 del informe “(...)”. Esta vulnerabilidad se considera de severidad media.

En la fase de pruebas CCC ha manifestado respecto de esta vulnerabilidad que no fue asumida, esto es, no se implementó en la medida en que la vulnerabilidad – y las consiguientes recomendaciones – no superaban el umbral de materialidad. Pero nada se dice en el informe acerca de no superar el umbral de materialidad.

(...)

Pero, es más, tampoco adoptó otras medidas de seguridad recomendadas a corto plazo en los informes de pentest realizados.

En este sentido cabe resaltar que en el informe de pentest referente a la auditoría realizada al canal web (www.carrefour.es) entre el 14 de febrero de 2023 y 3 de marzo de 2023, también se recogen, entre otras, las siguientes vulnerabilidades:

(...)

Sin embargo, según consta en el informe de Pentest a la Web Carrefour (Carrefour.es), para realizar las pruebas en la modalidad Caja Gris (...).

En este punto indica CCC que no fueron asumidas, esto es, no se implementaron en la medida en que las vulnerabilidades – y las consiguientes recomendaciones – no superaban el umbral de materialidad. Sin embargo, en el informe no se dice nada sobre que no superara el umbral de materialidad.

Por su parte, en el informe del pentest realizado al canal APP de Carrefour, entre el 6 de febrero de 2023 y el 9 de febrero de 2023, se recoge, entre otras, las siguientes vulnerabilidades:

- (...).

Respecto de estas vulnerabilidades Carrefour ha manifestado que las recomendaciones no fueron implementadas porque “no resultan de aplicación, en la medida en que son recomendaciones derivadas de vulnerabilidades que fueron detectadas como consecuencia de facilitar información al auditor sobre la infraestructura de los sistemas de CCC y de la eliminación de medidas de seguridad para facilitar el trabajo del auditor en el pentest en modalidad de caja gris.

Sin embargo, se recoge en el punto 3 del informe de pentest de la APP que “(...)”.

Según se recoge en la página oficial del Instituto Nacional de Ciberseguridad existen diferentes tipos de pruebas de penetración (pentesting) según la información inicial con la que cuenta el auditor, así, pueden ser:

- de caja blanca: si disponen de toda la información sobre los sistemas, aplicaciones e infraestructura, pudiendo simular que el ataque se realiza por alguien que conoce la empresa y sus sistemas;
- de caja gris: si dispone de algo de información, pero no de toda;
- de caja negra: si no dispone de información sobre nuestros sistemas; en este caso, se simula lo que haría un ciberdelincuente ajeno.

Por tanto, en la prueba de pentesting realizada en la APP no se facilitó al auditor ninguna información al no tratarse de una prueba de caja gris sino de caja negra.

En consecuencia, debe rechazarse esta alegación de CCC sobre la existencia de medidas adecuadas.

(ii) Indica CCC que hay que tener en cuenta que para la realización de las auditorías se desactivaron determinadas medidas de seguridad (caja gris).

Pero como se ha indicado anteriormente, la prueba de pentests realizada a la APP se hizo en la modalidad Caja Negra y, si bien es cierto que la realizada a la Web se inició en la modalidad Caja Gris, según consta en el informe de Pentest a la Web Carrefour (Carrefour.es), para realizar las pruebas en la modalidad Caja Gris (...), por lo que esta alegación debe ser igualmente rechazada.

(iii) En relación con las vulnerabilidades de nivel crítico y alto detectadas en los análisis Pentest de febrero de 2023, consta aportado documento con el informe de un auditor experto que certifica y acredita la corrección de la vulnerabilidad crítica. Este informe tiene fecha de 19 de julio de 2023.

Sin embargo, en relación con la vulnerabilidad de nivel alto (sobre el posible uso de software desactualizado y con vulnerabilidades conocidas), afirman que actualmente se encuentran trabajando en remediarlo. Y tampoco han sido implementadas otras recomendaciones para solucionar vulnerabilidades de nivel medio, recomendadas

para su aplicación a corto plazo, y ello a pesar, como se ha indicado, de los acontecimientos sufridos por Carrefour.

Todo ello no hace sino reflejar una falta de diligencia por parte de CCC a la hora de aplicar las medidas de seguridad adecuadas al riesgo de los tratamientos de datos que lleva a cabo. No debe olvidarse que tanto en la aplicación de CCC como en la web se tratan datos personales de miles de clientes, lo cual supone un tratamiento a gran escala, lo que exige medidas de seguridad adecuadas para ese entorno y dirigidas especialmente a garantizar que no se produzca un acceso ilegítimo a dichos datos personales.

(iv) Considera que, en este caso, si se entendieran infringidos los artículos 5.1 f) y 32 del RGPD (quod non), estaríamos ante una única infracción y que la supuesta falta de medidas técnicas y organizativas apropiadas debería entenderse comprendida, como medio de perpetración, en la infracción de los principios de integridad y confidencialidad.

Pues bien, la confidencialidad y la seguridad de los datos tienen su reflejo fundamentalmente en dos preceptos independientes del RGPD: en el artículo 5.1.f) y en el artículo 32 del RGPD.

El artículo 5.1.f) del RGPD es uno de los principios relativos al tratamiento. Los principios relativos al tratamiento son, por un lado, el punto de partida y la cláusula de cierre del ordenamiento jurídico de protección de datos, constituyendo verdaderas reglas informadoras del sistema con una intensa fuerza expansiva; por otro lado, al tener un alto nivel de concreción, son normas de obligado cumplimiento susceptibles de ser infringidas.

Pues bien, el artículo 5.1.f) del RGPD recoge el principio de integridad y confidencialidad y determina que los datos personales serán tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas. Establece una obligación de resultado, no objetiva.

Por otra parte, el artículo 32 del RGPD reglamenta cómo ha de articularse la seguridad del tratamiento en relación con las medidas de seguridad concretas que hay que implementar, de tal forma que teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo que incluya entre otras cuestiones, la capacidad de garantizar la confidencialidad de los datos.

Como podemos ver, el artículo 32 del RGPD, aunque relacionado con el artículo 5.1.f) del RGPD, no circunscribe el principio en su totalidad. El artículo 5.1.f) del RGPD exige taxativamente que se garantice la confidencialidad, y requiere para su imputación una pérdida de confidencialidad, disponibilidad o de integridad. Podemos encontrarnos con

supuestos en que existan medidas inadecuadas sin que por ello haya una pérdida de integridad, disponibilidad y confidencialidad.

La falta de medidas de seguridad constituye una vulneración autónoma e independiente y con suficiente entidad en sí misma, para ser sancionada sin necesidad de que se materialice una brecha de datos personales y no resulta necesaria la infracción del artículo 32 para que se pueda considerar la existencia de una infracción del artículo 5.1.f) del RGPD.

En el presente caso:

- La vulneración de los principios de integridad y confidencialidad, ambos establecidos en el citado artículo 5.1.f) del RGPD, se manifiesta en el acceso ilegítimo a cuentas de clientes por parte de terceros no autorizados, en algunos casos pudiendo incluso modificar datos personales y realizar compras, lo que motivó la notificación de hasta cinco brechas de datos personales por parte del responsable de tratamiento CARREFOUR. Asimismo, se evidencia en la inadecuada gestión de las violaciones de la seguridad de los datos personales.

- La vulneración del artículo 32 del RGPD se infiere de las manifestaciones de la propia entidad investigada que reconoce en el transcurso de las actuaciones de investigación que la mayoría de las reglas se basan en volumetrías por fallos desde una misma IP, de un mismo usuario o por rangos específicos. Sin embargo, el sistema permitía que se utilizaran para los accesos, más de 7000 direcciones IP distintas de diferentes proveedores de red, por tanto, las medidas de seguridad implementadas eran insuficientes. Lo que supone una vulneración del artículo 32 del RGPD. Asimismo, se deriva de la falta de implementación de las medidas recomendadas en los informes de pentest y que evitarían, en caso de sufrir un ataque, que el atacante tuviera acceso a datos personales.

Subsidiariamente, considera que deberán tenerse en cuenta las siguientes circunstancias:

- o La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido (artículo 83.2 a) del RGPD)

Entiende que existe una incongruencia en el acuerdo de inicio y o se considera como agravante el hecho de que haya habido una afectación de los Datos Personales Afectados (en cuyo caso deberá limitarse a los clientes efectivamente afectados, no a todos los usuarios de la web y la aplicación) o, por el contrario, se considera como agravante el hecho de que la afectación por la falta de medidas técnicas y organizativas afecta a todos los usuarios de la web y la aplicación (en cuyo caso no podrá defenderse que ha habido una efectiva afectación de sus datos personales, puesto que la misma se ha producido solo en determinados casos).

En cualquier caso, considera que, a pesar de que en determinados casos se haya visto afectado un conjunto de datos (nombre y apellidos, dirección postal completa y fecha de nacimiento), los mismos no son críticos, máxime si tenemos en cuenta que el

fin último perseguido por el tercero es cometer un fraude económico, siendo los datos personales afectados un medio para cometer dicho fraude, no un fin en sí mismo.

En relación con la duración, se ha visto cómo la aplicación progresiva de nuevas medidas fue reduciendo el impacto (implantación del segundo factor para modificar datos personales y para acceder a la aplicación, entre otros), por lo que entiende que esta circunstancia no podrá ser tenida en cuenta como agravante.

En cuanto a esta agravante el foco se pone en la ausencia de medidas de seguridad que afecta a los datos personales de los clientes de Carrefour usuarios de la web y de la APP. Esta amplia afectación amplifica la gravedad de la infracción, dado que existió para cada cliente riesgo de pérdida de confidencialidad, disponibilidad e integridad.

Además, en cuanto a la duración de la infracción, la ausencia de medidas se extiende al menos hasta el 8 de noviembre de 2024, fecha de presentación por Carrefour de la respuesta a las pruebas solicitadas, habida cuenta que existen medidas técnicas u organizativas necesarias que no han sido aplicadas.

- o La intencionalidad o negligencia en la infracción (artículo 83.2 b) del RGPD

Respecto de esta circunstancia, no cabe duda de que de la documentación obrante en el procedimiento se desprende una grave falta de diligencia en la gestión de la seguridad de los datos personales.

También, CCC entiende que deberán tenerse en cuenta las siguientes circunstancias como atenuantes:

- i. Cualquier otra medida tomada por el responsable del tratamiento para paliar los daños y perjuicios sufridos por los interesados (artículo 83.2 c) del RGPD)*

CCC adoptó medidas técnicas y organizativas dirigidas a disminuir la probabilidad de materialización del riesgo. Además, estas medidas fueron adoptadas de forma proactiva, esto es, con anterioridad a tener conocimiento de las investigaciones de la Agencia que han acabado en el dictado del Acuerdo de Inicio.

Como se ha indicado anteriormente, CCC no habría adoptado medidas para impedir que terceros no autorizados explotaran las vulnerabilidades identificadas.

- ii. El grado de cooperación con la autoridad de control con el fin deponer remedio a la infracción y mitigar los posibles efectos adversos de la infracción (artículo 83.2 f) del RGPD), así como la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable notificó la infracción y, en tal caso, en qué medida (artículo 83.2 h del RGPD).*

Nos remitimos a lo expuesto para esta circunstancia en la Alegación Segunda.

En consecuencia, las alegaciones deben ser desestimadas, significándose que las argumentaciones presentadas no desvirtúan el contenido esencial de las infracciones que se declaran cometidas ni suponen causa de justificación o exculpación suficiente.

ALEGACIÓN CUARTA. CCC reconoce su responsabilidad en relación con la presunta infracción del artículo 34 de RGPD: comunicación de las brechas a las personas afectadas.

Aunque CCC consideró en su momento que no era preceptiva la comunicación de las brechas a las personas afectadas, CCC reconoce su responsabilidad única y exclusivamente por la presunta infracción del artículo 34 del RGPD en relación con aquellas personas que vieron afectadas la confidencialidad y/o integridad de sus datos personales, lo que deberá llevar aparejada una reducción de un 20% de la sanción propuesta para esta infracción (200.000 euros). Asimismo, en caso de que el pago se realizara antes de la resolución del presente procedimiento, la sanción debería reducirse en un 20% adicional, siendo la cuantía que pagar 120.000 euros.

La entidad investigada reconoce su responsabilidad, solicitando las reducciones del importe de la sanción previstas en la normativa.

El artículo 85.1 de la LPACAP señala que *“Iniciado un procedimiento sancionador, si el infractor reconoce su responsabilidad, se podrá resolver el procedimiento con la imposición de la sanción que proceda.”*

Por ello, en el acuerdo de inicio del presente procedimiento sancionador se indicaba que *“De conformidad con lo dispuesto en el artículo 85 de la LPACAP, podrá reconocer su responsabilidad dentro del plazo otorgado para la formulación de alegaciones al presente acuerdo de inicio; lo que llevará aparejada una reducción de un 20% de la sanción que proceda imponer en el presente procedimiento”.*

Por otro lado, en el mismo acuerdo de inicio se señalaba que *“Del mismo modo podrá, en cualquier momento anterior a la resolución del presente procedimiento, llevar a cabo el pago voluntario de la sanción propuesta, lo que supondrá la reducción de un 20% de su importe.”* Con indicación de que dicho pago implicará la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes.

Por otro lado, el artículo 85.3 de la LPACAP señala que la efectividad de tal reducción *“estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción”*. Este aspecto también se recoge en el mencionado acuerdo de inicio del presente procedimiento sancionador, el cual también señala que *“En todo caso, la efectividad de cualquiera de las dos reducciones mencionadas estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.”*

Por tanto, si bien la entidad investigada ha reconocido su responsabilidad dentro del plazo para formular alegaciones al acuerdo de inicio, éste no ha venido acompañado ni del desistimiento o renuncia a interponer cualquier acción o recurso en vía administrativa contra la sanción, ni del pago de esta, por lo que de conformidad con lo establecido en el artículo 85.2 de la LPACAP, se le informa de que podrá, en cualquier momento anterior a la resolución del presente procedimiento, poner de manifiesto el desistimiento o renuncia expresa a la vía administrativa, así como llevar a cabo el pago voluntario de la sanción propuesta, lo que supondrá una reducción de un 20% del importe de la misma y su pago implicará la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes.

IV

Obligación incumplida. Principio de integridad y de confidencialidad.

Establece el artículo 5.1.f) del RGPD lo siguiente:

“Artículo 5 Principios relativos al tratamiento:

1. *Los datos personales serán:*

(...)

f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»).”

En relación con este principio, el Considerando 39 del referido RGPD señala que:

“[...]Los datos personales deben tratarse de un modo que garantice una seguridad y confidencialidad adecuadas de los datos personales, inclusive para impedir el acceso o uso no autorizados de dichos datos y del equipo utilizado en el tratamiento”.

Según las Directrices sobre la notificación de las violaciones de la seguridad de los datos personales de acuerdo con el Reglamento 2016/679 del GT29 se produce una «violación de la confidencialidad» cuando se produce una revelación no autorizada o accidental de los datos personales, o el acceso a los mismos; una «violación de la integridad»: cuando se produce una alteración no autorizada o accidental de los datos personales; y una «violación de la disponibilidad»: cuando se produce una pérdida de acceso accidental o no autorizada a los datos personales, o la destrucción de los mismos.

El principio de confidencialidad e integridad, dentro del marco del RGPD, implica la obligación de garantizar que los datos personales se mantengan protegidos y únicamente puedan ser accesibles o modificados por aquellos que tienen autorización para su tratamiento, con el fin legítimo previsto por el responsable del tratamiento.

En el caso que nos ocupa, de las actuaciones de investigación realizadas por la presente autoridad, se desprende una presunta vulneración del citado principio de confidencialidad e integridad. Dicha vulneración se manifiesta en primer lugar en las brechas de datos personales sufridas por la entidad y notificadas por la propia entidad investigada y que son:

(...)

El hecho de que los atacantes accedieran de forma ilegítima a las cuentas de los clientes haciendo uso probablemente de la técnica de ataque de Credential Stuffing utilizando credenciales filtradas (pares de email/ contraseña), con independencia de la forma en que accedieran a dichas credenciales,- y que pudieran modificar datos personales y realizar compras, constituye una manifestación de la vulneración de los

principios de integridad y confidencialidad, ambos establecidos en el citado artículo 5.1.f) del RGPD.

En este sentido, no debe olvidarse, tal y como ha quedado expuesto en las actuaciones de investigación y de la información transmitida, que los atacantes accedieron a datos personales de los clientes y los modificaron, esto último, al menos en la primera brecha notificada.

Del elevado número de accesos a datos personales, aumenta el riesgo de uso indebido y fraude y pone de manifiesto que las medidas técnicas y organizativas adoptadas por el responsable antes y tras los incidentes no fueron las apropiadas para garantizar la integridad y confidencialidad adecuada de los datos personales, en especial para la protección contra el tratamiento no autorizado o ilícito.

El art. 24 del RGPD sobre la responsabilidad del responsable del tratamiento, dispone en su apartado 1 que “Teniendo en cuenta la naturaleza, el ámbito, el contexto y los fines del tratamiento, así como los riesgos de diversa probabilidad y gravedad para los derechos y libertades de las personas físicas, el responsable del tratamiento aplicará medidas técnicas y organizativas apropiadas a fin de garantizar y poder demostrar que el tratamiento es conforme con el presente Reglamento. Dichas medidas se revisarán y actualizarán cuando sea necesario. (el subrayado es nuestro)

Por su parte, el Considerando 74 del RGPD declara que “*Debe quedar establecida la responsabilidad del responsable del tratamiento por cualquier tratamiento de datos personales realizado por él mismo o por su cuenta. En particular, el responsable debe estar obligado a aplicar medidas oportunas y eficaces y ha de poder demostrar la conformidad de las actividades de tratamiento con el Reglamento General de Protección de Datos, incluida la eficacia de las medidas. Dichas medidas deben tener en cuenta la naturaleza, el ámbito el contexto y los fines del tratamiento, así como el riesgo para los derechos y libertades de las personas físicas*”

Y añade el Considerando 76 que “*La probabilidad y la gravedad del riesgo para los derechos y libertades del interesado debe determinarse con referencia a la naturaleza, el alcance, el contexto y los fines del tratamiento de datos. El riesgo debe ponderarse sobre la base de una evaluación objetiva mediante la cual se determine si las operaciones de tratamiento de datos suponen un riesgo o si el riesgo es alto*”

Las Directrices WP248 del GT29, sobre la evaluación de impacto relativa a la protección de datos (EIPD) y para determinar si el tratamiento «entraña probablemente un alto riesgo» a efectos del RGPD, adoptadas el 4 de abril de 2017 y revisadas por última vez y adoptadas el 4 de octubre de 2017, definen los conceptos de “riesgo” y de “gestión del riesgo”. Un «riesgo» es un escenario que describe un acontecimiento y sus consecuencias estimado en términos de gravedad y probabilidad. Por otra parte, la «gestión de riesgos» puede definirse como las actividades coordinadas para dirigir y controlar una organización respecto al riesgo.

Tal y como recoge la guía de esta AEPD sobre “Gestión del riesgo y evaluación de impacto en tratamientos de datos personales”, “*F de reacción ante la brecha, el responsable tendrá que abordar, dentro del ciclo de gestión del riesgo, todas aquellas medidas que fueran necesarias para prevenir que el incidente o la brecha pudieran*

volver a ocurrir. Esta tarea implicará la revisión de los controles que estuvieran relacionados con la ocurrencia de la brecha, así como posible la implantación de nuevos controles que pudieran ser necesario” Lo que implicará, por lo que aquí interesa, la aplicación de aquellos recursos, procedimientos y controles que pudieran ser necesarios para garantizar el cumplimiento del principio de integridad y confidencialidad, lo que no consta que se haya realizado en este caso.

En este sentido, la referida guía también recoge *“Como interpreta la Declaración WP218, hay que subrayar que abordar los riesgos que pudiera entrañar un tratamiento de datos para los derechos y libertades de las personas no puede limitarse a aplicar exclusivamente medidas de seguridad. Por lo tanto, la gestión de los riesgos de seguridad es una más de las actividades para la gestión de los riesgos para los derechos y libertades y se tiene que supeditar a esta última. Además, desde el punto de vista del RGPD, las medidas de mitigación han de estar orientadas a reducir el impacto y la probabilidad de que las brechas de datos personales afecten al interesado”*.

En el caso presente, se materializaron 5 violaciones de datos personales haciendo los atacantes uso probablemente de la técnica de ataque de Credential Stuffing, al confirmar Carrefour que no existieron ataques de fuerza bruta y que se ofrecían credenciales de clientes, sin que Carrefour haya acreditado que adoptara medidas técnicas y organizativas, no sólo de seguridad, adecuadas para evitar que la pérdida de integridad y confidencialidad se volviera a producir o para reducir eficazmente la probabilidad de su materialización, como comprobar la efectividad de los recursos, procedimientos y controles incorporados, reevaluando el riesgo y realizando las revisiones necesarias en un plazo adecuado para garantizar la confidencialidad e integridad de los datos personales, lo que queda evidenciado que no se hizo.

Carrefour no implantó de modo diligente el doble factor de autenticación que habría impedido el acceso a las cuentas cuyas credenciales se podrían haber visto afectadas por las brechas. Procede reseñar que las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, no pueden ser en modo alguno sólo medidas reactivas, es decir, exclusivamente para solucionar de forma inmediata una brecha de datos personales después de sucedida. Conviene recordar que la implementación del Doble Factor de Autenticación (2FA) si bien constituyó un avance significativo en la protección de la seguridad de los datos, este avance llegó tardíamente en un momento reactivo, después de que se hubieran manifestado vulnerabilidades críticas y se hubieran producido hasta 5 brechas de datos personales con efectos amplios.

Y no sólo se precia una gestión inadecuada de las violaciones de la seguridad de los datos personales en la tardía implantación del 2FA, al menos en el canal web, sino en otras circunstancias. Así, se ha constatado un impacto en la primera brecha de 234 afectados, en la segunda brecha: 35.735 afectados, en la tercera brecha: 61.083 afectados, en la cuarta brecha 10.943 y en la quinta brecha 10.900 afectados. CCC ha manifestado que reseteó las contraseñas afectadas tras las sucesivas brechas y que en la cuarta brecha volvieron a estar comprometidas las credenciales de 1.741 clientes afectados también en la tercera brecha. Sin embargo, de los 10.943 clientes afectados en la cuarta brecha sólo se recetaron las contraseñas de 9.202 clientes, sin que fueran nuevamente reseteadas las contraseñas de los 1.741 clientes porque ya fueron

reseteadas tras la tercera brecha, quedando sin resetear esas 1.741 credenciales que habían quedado comprometidas nuevamente.

En este sentido, no debe olvidarse, tal y como ha quedado expuesto en las actuaciones de investigación y de la información transmitida, que se produjo un acceso ilegítimo a datos personales por un tercero no autorizado, lo que supuso la pérdida de confidencialidad y de control de numerosos datos personales y que afectó a todos aquellos cuyos datos fueron conocidos, no solo a aquellos clientes cuyos datos fueron luego suplantados.

En cuanto a la tipología de datos personales a los que se pudo tener acceso el atacante en la segunda brecha de datos personales, una vez implantadas las medidas reactivas tras la primera brecha detectada en enero de 2023, se incluye por la propia entidad investigada un listado de datos personales a los que se pudo tener acceso, organizados por tipología de datos:

- o *Nombre, Apellido 1, Apellido 2*
- o *Correo Electrónico*
- o *Teléfono de contacto (enmascarado con asteriscos todos los dígitos exceptuando los 3 últimos)*
- o *DNI (enmascarado con asteriscos todos los caracteres exceptuando los 4 últimos)*
- o *Dirección postal completa: Código postal, Escalera/piso/puerta, Municipio, Nombre de la vía, Número de la vía, Provincia, Tipo de vía, Fecha de nacimiento."*

Asimismo, consta en la notificación de la tercera brecha de datos personales, que se produjo el 16 de abril 2023, que el atacante tuvo acceso a Datos básicos (Ej: nombre, apellidos, fecha de nacimiento), DNI, NIE, Pasaporte y / o cualquier otro documento identificativo, Datos económicos o financieros (sin medios de pago), Datos de contacto, Credenciales de acceso o identificación (usuario y / o contraseña).

En la notificación de la cuarta brecha de datos personales, ocurrida el 23 de junio 2023, consta que el atacante accedió a datos básicos (Ej: nombre, apellidos, fecha de nacimiento), Datos de contacto, Credenciales de acceso o identificación (usuario y / o contraseña).

En la notificación de la quinta brecha de datos personales, ocurrida el 11 de septiembre, de 2023 consta que el atacante tuvo acceso a datos básicos (Ej: nombre, apellidos, fecha de nacimiento), DNI, NIE, Pasaporte y / o cualquier otro documento identificativo, Datos de contacto, Credenciales de acceso o identificación (usuario y / o contraseña).

En consecuencia, se considera que los hechos acreditados son constitutivos de una infracción, imputable a la entidad investigada, por vulneración del artículo 5.1.f) del RGPD.

V

Tipificación y calificación de la infracción

La citada infracción del artículo 5.1.f) del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.5 del RGPD que bajo la rúbrica “*Condiciones generales para la imposición de multas administrativas*” dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9; (...)”

A este respecto, la LOPDGDD, en su artículo 71 “*Infracciones*” establece que “*Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica*”.

A efectos del plazo de prescripción, el artículo 72 “*Infracciones consideradas muy graves*” de la LOPDGDD indica:

“1. En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

a) El tratamiento de datos personales vulnerando los principios y garantías establecidos en el artículo 5 del Reglamento (UE) 2016/679. (...)”

VI Sanción

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

“1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 5 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.

2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;

b) la intencionalidad o negligencia en la infracción;

c) cualquier medida tomada por el responsable o encargado del tratamiento para

paliar los daños y perjuicios sufridos por los interesados;
d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;
e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;
f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;
g) las categorías de los datos de carácter personal afectados por la infracción;
h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida; i) *cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;*
j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42,
k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción.”

Por su parte, el artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD dispone:

“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.

2. De acuerdo con lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado.”*

De acuerdo con los preceptos transcritos, a efectos de fijar el importe de la sanción por infracción del artículo 5.1 f) del RGPD, procede graduar la multa teniendo en cuenta:

Como circunstancia de graduación de la sanción se tienen en cuenta:

Artículo 83.2 a) RGPD: *“la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se*

trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido”;

Conviene señalar que la vulneración del principio de integridad y confidencialidad en el presente caso involucra un conjunto de datos personales cuya naturaleza amplifica las implicaciones de la brecha de seguridad. Ello se desprende en la circunstancia de que se han visto afectados determinados datos personales como son nombre, Apellido 1, Apellido 2, Correo Electrónico, Dirección postal completa: Código postal, Escalera/piso/puerta, Municipio, Nombre de la vía, Número de la vía, Provincia, Tipo de vía, Fecha de nacimiento, y credenciales, cuya exposición aumenta el riesgo de uso indebido y fraude y de ataques de ingeniería social y estafa informática.

La combinación de este tipo de datos personales eleva significativamente el nivel de riesgo para los derechos y libertades de sus titulares y las implicaciones de la vulneración de la confidencialidad. Esto se debe a la circunstancia de que dicha combinación no solo aumenta la cantidad de información disponible para un actor malicioso, sino que también amplía el espectro de posibles abusos. Dado que no se trata de datos aislados o piezas individuales de información, sino de la exposición de un conjunto integrado de datos personales que cuando se combinan, pueden ser utilizados para construir un perfil completo y detallado de un individuo, lo cual puede permitir a un atacante realizar operaciones de fraude y suplantación de identidad con una mayor tasa de éxito.

De forma concreta, se realizaron pedidos on line y a través de pago con QR en las tiendas físicas, así como que accedieron a cuentas usurpadas a través de otros dispositivos empleando cupones de los clientes. Este nivel de acceso aumenta el riesgo de uso indebido y fraude y de pérdida de control sobre sus datos personales.

Por último, no puede obviarse el número considerable de afectados de las brechas, dado que se ha constatado un impacto en la primera brecha: 234 afectados, en la segunda brecha: 35.735 afectados, en la tercera brecha: 61.083 afectados, en la cuarta brecha 10.943 y en la quinta brecha de 10.900 afectados, lo que resalta tanto la escala del incidente como el volumen considerable de individuos cuyos derechos y libertades fueron comprometidos. Esta amplia afectación amplifica la gravedad de la infracción, dado que cada cliente afectado representa un potencial caso de fraude, suplantación de identidad, o pérdida financiera, multiplicando exponencialmente las repercusiones negativas del incidente.

Además, la infracción se ve agravada por el contexto en el que se produce, donde los individuos confían en la entidad para el manejo seguro de su información personal, habiéndose erosionado la confianza y expectativas de los afectados respecto al tratamiento de sus datos personales.

Artículo 83.2 b) RGPD: *“La intencionalidad o negligencia en la infracción”*

El Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la entidad reclamada es de constante y

abundante manejo de datos de carácter personal, ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto. [Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006)].

De las actuaciones de investigación desarrolladas por la presente autoridad, se desprende una posible insuficiencia de medidas técnicas y organizativas para una gestión adecuada de las violaciones de seguridad de los datos personales, que puede inferirse fácilmente del hecho de que, a pesar de que todas las brechas tuvieron como vector de entrada el acceso ilegítimo a cuentas de clientes, no fue hasta después de la quinta brecha (en concreto el 30 de octubre de 2023) cuando se decide implantar el 2FA (con envío de clave OTP) para los inicios de sesión del canal digital Ecommerce. Disponer de esta medida con anterioridad hubiera evitado con gran probabilidad todos los ataques producidos en este canal, lo que pone de manifiesto la falta de diligencia de CARREFOUR en el cumplimiento del deber de adoptar las medidas adecuadas para garantizar la confidencialidad e integridad de los datos.

La implementación del Doble Factor de Autenticación (2FA) constituyó, sin duda, un avance significativo en la protección de la seguridad de los datos. Sin embargo, este avance llegó tarde en un momento reactivo, después de que se hubieran manifestado vulnerabilidades críticas y se produjeran hasta 5 brechas de datos personales con efectos amplios y con el mismo vector de entrada.

Dicha circunstancia refleja una omisión palmaria del responsable en el deber de cuidado hacia la protección de los datos de sus clientes, lo que refuerza y amplifica la gravedad de la infracción.

Artículo 76.2 b) LOPDGDD: “La vinculación de la actividad del infractor con la realización de tratamientos de datos personales”

La actividad empresarial de la entidad investigada exige un continuo tratamiento de datos de carácter personal. La empresa opera en un sector donde la confianza y la seguridad de la información resulta fundamental, y por tal motivo tiene la responsabilidad garantizar con mayor rigurosidad los principios de protección de datos respecto a la información que gestiona en virtud de dicha actividad.

Considerando los factores expuestos, la valoración que alcanza la cuantía de la multa es de 2.000.000 euros por infracción del artículo 5.1 f) del RGPD.

VII

Obligación incumplida. Seguridad del tratamiento.

Establece el artículo 32 del RGPD, *seguridad del tratamiento*, lo siguiente:

“1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

- a) la seudonimización y el cifrado de datos personales;
- b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;
- c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;
- d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

3. La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.

4. El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros”.

El Considerando 74 del RGPD, anteriormente reproducido, establece:

“Debe quedar establecida la responsabilidad del responsable del tratamiento por cualquier tratamiento de datos personales realizado por él mismo o por su cuenta. En particular, el responsable debe estar obligado a aplicar medidas oportunas y eficaces y ha de poder demostrar la conformidad de las actividades de tratamiento con el presente Reglamento, incluida la eficacia de las medidas. Dichas medidas deben tener en cuenta la naturaleza, el ámbito, el contexto y los fines del tratamiento, así como el riesgo para los derechos y libertades de las personas físicas.”

Hay que señalar que el RGPD en el citado precepto no establece un listado de medidas, tampoco de las medidas de seguridad que sean de aplicación de acuerdo con los datos que son objeto de tratamiento, sino que establece que el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas que sean adecuadas al riesgo que conlleve el tratamiento, teniendo en cuenta el estado de la técnica, los costes de aplicación, la naturaleza, alcance, contexto y finalidades del tratamiento, los riesgos de probabilidad y gravedad para los derechos y libertades de las personas interesadas.

Asimismo, las medidas de seguridad deben resultar adecuadas y proporcionadas al riesgo detectado, señalando que la determinación de las medidas técnicas y organizativas deberá realizarse teniendo en cuenta: la seudonimización y el cifrado, la capacidad para garantizar la confidencialidad, integridad, disponibilidad y resiliencia, la capacidad para restaurar la disponibilidad y acceso a datos tras un incidente, proceso

de verificación (que no auditoría), evaluación y valoración de la eficacia de las medidas.

En todo caso, al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos y que pudieran ocasionar daños y perjuicios físicos, materiales o inmateriales.

En este mismo sentido el considerando 83 del RGPD señala que:

“(83) A fin de mantener la seguridad y evitar que el tratamiento infrinja lo dispuesto en el presente Reglamento, el responsable o el encargado deben evaluar los riesgos inherentes al tratamiento y aplicar medidas para mitigarlos, como el cifrado. Estas medidas deben garantizar un nivel de seguridad adecuado, incluida la confidencialidad, teniendo en cuenta el estado de la técnica y el coste de su aplicación con respecto a los riesgos y la naturaleza de los datos personales que deban protegerse. Al evaluar el riesgo en relación con la seguridad de los datos, se deben tener en cuenta los riesgos que se derivan del tratamiento de los datos personales, como la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos, susceptibles en particular de ocasionar daños y perjuicios físicos, materiales o inmateriales”.

La responsabilidad de CCC viene determinada por la falta de medidas de seguridad, ya que es responsable de tomar decisiones destinadas a implementar de manera efectiva las medidas de seguridad técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo para proteger la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento.

De la documentación obrante en el procedimiento puede inferirse esta carencia de medidas adecuadas al riesgo para los derechos y libertades de las personas físicas, toda vez que el sistema permitía que se utilizaran para los accesos más de 7000 direcciones IP distintas de diferentes proveedores de red, lo que motivó que Carrefour tuviera que adquirir una herramienta específica que detectara patrones anómalos.

La ausencia de medidas adecuadas, también se pone de manifiesto en los informes de la auditoría Pentest, en los que se acreditaron deficiencias en los controles implementados en los sistemas de información de la entidad investigada, que comprometían la confidencialidad e integridad de la información, sin que se hayan aplicado las recomendaciones recogidas en los mismos.

El Informe del Pentest a la web Carrefour (Carrefour.es) realizado por *****EMPRESA.1**, contiene las siguientes recomendaciones y acciones generales a realizar a corto plazo:

-(...).

Asimismo, el Informe del Pentest a la APP Carrefour para Android/iOS, contiene las siguientes recomendaciones generales sobre acciones a realizar:

“(…)”.

En particular, en la auditoría realizada al canal web (www.carrefour.es) entre el 14 de febrero de 2023 y 3 de marzo de 2023, (…).

Asimismo, constan en el informe de pentest referente a la auditoría realizada al canal web (www.carrefour.es), entre otras, las siguientes vulnerabilidades:

(…)

Por su parte, en el informe del pentest realizado al canal APP de Carrefour, entre el 6 de febrero de 2023 y el 9 de febrero de 2023, se recoge, entre otras, las siguientes vulnerabilidades:

- (…).

Respecto de estas tres recomendaciones Carrefour ha manifestado que no fueron implementada porque “(…)”.

Sin embargo, se recoge en el punto 3 del informe de pentest de la APP que “(…)”.

Por tanto, de lo que antecede se desprende que las medidas de seguridad técnicas y organizativas implantadas por la entidad no constituyen un nivel de seguridad adecuado al riesgo y no son adecuadas para impedir un acceso no autorizado a los datos de los clientes.

En consecuencia, se considera que los hechos acreditados son constitutivos de una infracción, imputable a la entidad investigada, por vulneración del artículo 32 RGPD, toda vez que conocía la existencia de vulnerabilidades que podían comprometer la integridad y confidencialidad de los datos personales y no adoptó medidas técnicas y organizativas para evitarlo.

VIII

Tipificación y calificación de la infracción

La citada infracción del artículo 32 del RGPD, supone la comisión de las infracciones tipificadas en el artículo 83.4 del RGPD que bajo la rúbrica “*Condiciones generales para la imposición de multas administrativas*” dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

- a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43; (…)”*

A este respecto, la LOPDGDD, en su artículo 71 “*Infracciones*” establece que “*Constituyen infracciones los actos y conductas a las que se refieren los apartados 4,*

5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica”.

A efectos del plazo de prescripción, el artículo 73 “Infracciones consideradas graves” de la LOPDGD indica:

“En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

- f) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento, en los términos exigidos por el artículo 32.1 del Reglamento (UE) 2016/679.”*

IX Sanción

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

“1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 5 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.

2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

- a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;*
- b) la intencionalidad o negligencia en la infracción;*
- c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;*
- d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;*
- e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;*
- f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;*
- g) las categorías de los datos de carácter personal afectados por la infracción;*
- h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;*
- i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en*

relación con el mismo asunto, el cumplimiento de dichas medidas;
j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42,
k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción.”

Por su parte, el artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD dispone:

“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.

2. De acuerdo con lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado.”*

De acuerdo con los preceptos transcritos, a efectos de fijar el importe de la sanción por infracción del artículo 32 del RGPD, procede graduar la multa teniendo en cuenta:

Como circunstancia de graduación de la sanción se tienen en cuenta:

Artículo 83.2 a) RGPD: *“la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido”;*

En cuanto al número de interesados afectados, la ausencia de medidas de seguridad afecta a todos los clientes del canal web Ecommerce (carrefour.es) y de la aplicación MiCarrefour. Esta amplia afectación amplifica la gravedad de la infracción, dado que existe para cada cliente riesgo una deficiente protección de sus datos personales.

Además, en cuanto a la duración de la infracción, la ausencia de medidas se entiende hasta el 8 de noviembre de 2024, fecha de presentación por Carrefour de la respuesta a las pruebas solicitadas, habida cuenta que las medidas técnicas u organizativas

necesarias al menos para solucionar los problemas detectados no habían sido aplicadas.

Artículo 83.2 b) RGPD: *“La intencionalidad o negligencia en la infracción”*

El Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la entidad reclamada es de constante y abundante manejo de datos de carácter personal, ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto. [Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006)].

De las actuaciones realizadas, se desprende una insuficiencia de medidas de seguridad existentes, y una grave falta de diligencia en la gestión de la seguridad de los datos personales.

Dicha circunstancia refleja una omisión palmaria en el deber del responsable hacia la protección de la seguridad de los datos de sus clientes, lo que refuerza y amplifica la gravedad de la infracción y justifica, en consecuencia, la concurrencia de esta agravante.

Artículo 76.2 b) LOPDGDD: *“La vinculación de la actividad del infractor con la realización de tratamientos de datos personales”*

La actividad empresarial de la entidad investigada exige un continuo tratamiento de datos de carácter personal. Por otra parte, la empresa opera en un sector donde la confianza y la seguridad de la información resulta fundamental, y por tal motivo tiene la responsabilidad de garantizar con mayor rigurosidad los principios de protección de datos respecto a la información que gestiona en virtud de dicha actividad. La naturaleza de dicha actividad exigía una mayor rigurosidad en la adopción de las medidas de seguridad, exigencia que no fue materializada en el caso que nos ocupa.

Considerando los factores expuestos, la valoración que alcanza la cuantía de la multa es de 1.000.000 euros por infracción del artículo 32 del RGPD.

X

Obligación incumplida. Comunicación de una violación de seguridad de los datos personales al interesado.

El artículo 34 “Comunicación de una violación de la seguridad de los datos personales al interesado” del RGPD establece:

“1. Cuando sea probable que la violación de la seguridad de los datos personales entrañe un alto riesgo para los derechos y libertades de las personas físicas, el responsable del tratamiento la comunicará al interesado sin dilación indebida.”

2. La comunicación al interesado contemplada en el apartado 1 del presente artículo describirá en un lenguaje claro y sencillo la naturaleza de la violación de la seguridad de los datos personales y contendrá como mínimo la información y las medidas a que se refiere el artículo 33, apartado 3, letras b), c) y d).

3. La comunicación al interesado a que se refiere el apartado 1 no será necesaria si se cumple alguna de las condiciones siguientes:

- a) el responsable del tratamiento ha adoptado medidas de protección técnicas y organizativas apropiadas y estas medidas se han aplicado a los datos personales afectados por la violación de la seguridad de los datos personales, en particular aquellas que hagan ininteligibles los datos personales para cualquier persona que no esté autorizada a acceder a ellos, como el cifrado;
- b) el responsable del tratamiento ha tomado medidas ulteriores que garanticen que ya no exista la probabilidad de que se concrete el alto riesgo para los derechos y libertades del interesado a que se refiere el apartado 1;
- c) suponga un esfuerzo desproporcionado. En este caso, se optará en su lugar por una comunicación pública o una medida semejante por la que se informe de manera igualmente efectiva a los interesados.

4. Cuando el responsable todavía no haya comunicado al interesado la violación de la seguridad de los datos personales, la autoridad de control, una vez considerada la probabilidad de que tal violación entrañe un alto riesgo, podrá exigirle que lo haga o podrá decidir que se cumple alguna de las condiciones mencionadas en el apartado 3”.

Por lo que respecta a la primera, segunda y tercera quiebra de datos personales, se ha de señalar que, si bien Carrefour no ha acreditado que realizara a los afectados una comunicación en los términos previstos en el art. 34 del RGPD, la posible infracción por su ausencia ha de considerarse prescrita, en virtud de lo dispuesto en el art. 74 de la LOPDGDD.

En cuanto a la cuarta y quinta quiebra de datos personales, en el presente caso, ha quedado constatado el envío de un comunicado en fecha 23 de junio de 2023, a 9202 afectados y en fecha 11 de septiembre de 2023, a 10.959 afectados, correspondientes a la cuarta y quinta brecha de seguridad, respectivamente.

De las actuaciones de investigación desarrolladas por la presenta autoridad la propia entidad investigada afirma que procedió a la comunicación por medio de correo electrónico, así como a través del canal push en los casos de clientes disponibles por este medio y siendo el contenido del mensaje enviado el siguiente:

“Estimado cliente:

Para ofrecerte un mejor servicio, hemos procedido a resetear tu contraseña. Para obtener una nueva solicítala en ¿has olvidado tu contraseña? al acceder a la App o a la web.

En la web

<https://www.carrefour.es/myaccount>

En la App

Identifícate y pulsa en ¿Has olvidado tu contraseña?

*Un saludo
El equipo de Carrefour*

En relación con el contenido que debe tener esta comunicación, el artículo 34.2 del RGPD se remite al artículo 33 del RGPD. De este modo, el contenido es el recogido en el artículo 33 apartado 3, letras b), c) y d) RGPD, que establece:

“3. La notificación contemplada en el apartado 1 deberá, como mínimo:

- b) comunicar el nombre y los datos del delegado de protección de datos o de otro punto de contacto en el que pueda obtenerse más información;*
- c) describir las posibles consecuencias de la violación de la seguridad de los datos personales;*
- d) describir las medidas adoptadas o propuestas por el responsable del tratamiento para poner remedio a la violación de seguridad, incluyendo, si procede, las medidas adoptadas para mitigar los posibles efectos negativos.”*

En el presente supuesto, el contenido del comunicado enviado no recoge las exigencias previstas en el artículo 33.3 apartados b), c) y d), y 34.2 del RGPD, toda vez que hace referencia a la circunstancia de que se ha procedido a resetear la contraseña, lo que, para un consumidor medio que lea el aviso, puede dar una idea de que existía una potencialidad para que se produjera una brecha, pero no evidencia una pérdida de confidencialidad como la que se produjo.

La redacción del comunicado no informa de manera apropiada sobre la existencia de una brecha de seguridad, no proporciona a las personas afectadas información sobre la naturaleza de la violación de seguridad sufrida, los datos personales afectados, consecuencias de la brecha, medidas adoptadas o propuestas para poner remedio a la violación, medidas para mitigar los posibles efectos negativos, datos de contacto del DPD u otro punto de contacto para obtener información adicional.

A este respecto, debe señalarse que el art. 34.2 RGPD señala que en la información a los afectados se “describirá en un lenguaje claro y sencillo la naturaleza de la violación de la seguridad de los datos personales”.

En consecuencia, se considera que los hechos acreditados son constitutivos de una infracción, imputable a entidad investigada por vulneración del artículo 34 del RGPD.

XI

Tipificación y calificación de la infracción

La citada infracción del artículo 34 del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.4 del RGPD que bajo la rúbrica “Condiciones generales para la imposición de multas administrativas” dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43; (...)

A este respecto, la LOPDGDD, en su artículo 71 “Infracciones” establece que “Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica”.

A efectos del plazo de prescripción, el artículo 74 “Infracciones consideradas leves” de la LOPDGDD indica:

“Se consideran leves y prescribirán al año las restantes infracciones de carácter meramente formal de los artículos mencionados en los apartados 4 y 5 del artículo 83 del Reglamento (UE) 2016/679 y, en particular, las siguientes:

“(...

ñ) El incumplimiento del deber de comunicación al afectado de una violación de la seguridad de los datos que entrañe un alto riesgo para los derechos y libertades de los afectados, conforme a lo exigido por el artículo 34 del Reglamento (UE) 2016/679, salvo que resulte de aplicación lo previsto en el artículo 73 s) de esta ley orgánica. (...)

XII Sanción

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

“1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 5 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.

2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

- a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;*
- b) la intencionalidad o negligencia en la infracción;*
- c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;*
- d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;*

- e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;
- f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;
- g) las categorías de los datos de carácter personal afectados por la infracción;
- h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;
- i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;
- j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42,
- k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción.”

Por su parte, el artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD dispone:

“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.

2. De acuerdo con lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado.”*

De acuerdo con los preceptos transcritos, a efectos de fijar el importe de la sanción por infracción del artículo 34 del RGPD, procede graduar la multa teniendo en cuenta:

Como circunstancia de graduación de la sanción se tienen en cuenta:

Artículo 83.2 a) RGPD: *“la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido”;*

Los hechos han afectado a determinados datos personales como son nombre, Apellido 1, Apellido 2, Correo Electrónico, Dirección postal completa: Código postal, Escalera/piso/puerta, Municipio, Nombre de la vía, Número de la vía, Provincia, Tipo de vía, Fecha de nacimiento, cuya exposición aumenta el riesgo de uso indebido y fraude.

El número de interesados afectados es elevado, dado que se ha constatado que las comunicaciones de brecha incompletas se remitieron, en fecha 23 de junio de 2023, a 9202 afectados y, en fecha 11 de septiembre de 2023, a 10.959 afectados, lo que resalta tanto la escala del incidente como el volumen considerable de individuos cuyos derechos y libertades fueron comprometidos. Esta amplia afectación amplifica la gravedad de la infracción, dado que cada cliente afectado representa un potencial caso de fraude, suplantación de identidad, o pérdida financiera, multiplicando exponencialmente las repercusiones negativas del incidente.

Además, la infracción se ve agravada por el contexto en el que se produce, donde los individuos confían en la entidad para el manejo seguro de su información personal, habiéndose erosionado la confianza y expectativas de los afectados respecto al tratamiento de sus datos personales.

Artículo 83.2 b) RGPD: *“La intencionalidad o negligencia en la infracción”* -en el cumplimiento de las obligaciones que le impone la normativa en materia de protección de datos, Carrefour ha actuado con negligencia grave a la hora de proporcionar a los afectados toda la información exigida por el citado artículo 34 del RGPD, para que pudieran adoptar rápidamente todas las medidas necesarias para protegerse de las consecuencias de las brechas de datos personales, teniendo en cuenta, además, el considerable volumen de afectados, lo cual supone un agravante.

Artículo 76.2 b) LOPDGDD: *“La vinculación de la actividad del infractor con la realización de tratamientos de datos personales”*

La actividad empresarial de la entidad investigada exige un continuo tratamiento de datos de carácter personal. La empresa opera en un sector donde la confianza y la seguridad de la información resulta fundamental, y por tal motivo tiene la responsabilidad garantizar con mayor rigurosidad los principios de protección de datos respecto a la información que gestiona en virtud de dicha actividad.

Considerando los factores expuestos, la valoración que alcanza la cuantía de la multa es de 200.000 euros por infracción del artículo 34 del RGPD.

XIII Adopción de medidas

En el texto de la resolución se establecen cuáles han sido las infracciones cometidas y los hechos que han dado lugar a la vulneración de la normativa de protección de datos, de lo que se infiere con claridad cuáles son las medidas a adoptar, sin perjuicio de que el tipo de procedimientos, mecanismos o instrumentos concretos para implementarlas corresponda a la parte sancionada, pues es el responsable del tratamiento quien conoce plenamente su organización y ha de decidir, en base a la

responsabilidad proactiva y en enfoque de riesgos, cómo cumplir con el RGPD y la LOPDGDD.

En el presente supuesto, por la presente autoridad, se procede a requerir al responsable, por lo que respecta a la vulneración del artículo 34, para que, en el plazo de un mes, notifique a esta Agencia la adopción de la siguiente medida: la comunicación de las brechas de datos personales a los afectados cuyos datos se hayan visto afectados en los términos y condiciones previstos por el artículo 34 del RGPD.

Se advierte que no atender la orden de adopción de medidas impuestas por este organismo en la resolución sancionadora podrá ser considerado como una infracción administrativa conforme a lo dispuesto en el RGPD, tipificada como infracción en su artículo 83.5 y 83.6, pudiendo motivar tal conducta la apertura de un ulterior procedimiento administrativo sancionador.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada, la Presidencia de la Agencia Española de Protección de Datos RESUELVE:

PRIMERO: IMPONER a CENTROS COMERCIALES CARREFOUR, S.A., con NIF A28425270,

- por la infracción del artículo 5.1.f) del RGPD, tipificada conforme a lo dispuesto en el artículo 83.5 del RGPD, calificada como muy grave a efectos de prescripción, en el artículo 72.1 a) de la LOPDGDD, una multa de 2.000.000 euros.
- por la infracción del artículo 32 del RGPD, tipificada conforme a lo dispuesto en el artículo 83.4 del RGPD, calificada como grave a efectos de prescripción, en el artículo 73 f) de la LOPDGDD, una multa de 1.000.000 euros.
- por la infracción del artículo 34) del RGPD, tipificada conforme a lo dispuesto en el artículo 83.4 del RGPD, calificada como leve a efectos de prescripción, en el artículo 74 ñ) de la LOPDGDD, una multa de 200.000 euros.

SEGUNDO: ORDENAR a CENTROS COMERCIALES CARREFOUR, S.A., con NIF A28425270, que en virtud del artículo 58.2.d) del RGPD, en el plazo de 1 mes desde que la presente resolución sea firme y ejecutiva, acredite haber procedido al cumplimiento de la siguiente medida: la comunicación de las brechas de datos personales a los afectados cuyos datos se hayan visto afectados en los términos y condiciones previstos por el artículo 34 del RGPD.

TERCERO: NOTIFICAR la presente resolución a CENTROS COMERCIALES CARREFOUR, S.A., con NIF A28425270.

CUARTO: Esta resolución será ejecutiva una vez finalice el plazo para interponer el recurso potestativo de reposición (un mes a contar desde el día siguiente a la notificación de esta resolución) sin que el interesado haya hecho uso de esta facultad.

Se advierte al sancionado que deberá hacer efectiva la sanción impuesta una vez que la presente resolución sea ejecutiva, de conformidad con lo dispuesto en el art. 98.1.b) de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, en el plazo de pago voluntario establecido en el art. 68 del Reglamento General de Recaudación, aprobado por Real Decreto 939/2005, de 29 de julio, en relación con el art. 62 de la Ley 58/2003, de 17 de diciembre, mediante su ingreso, indicando el NIF del sancionado y el número de procedimiento que figura en el encabezamiento de este documento, en la cuenta restringida nº **IBAN: ES00-0000-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)**, abierta a nombre de la Agencia Española de Protección de Datos, en la entidad bancaria CAIXABANK, S.A.. En caso contrario, se procederá a su recaudación en período ejecutivo.

Recibida la notificación y una vez ejecutiva, si la fecha de ejecutividad se encuentra entre los días 1 y 15 de cada mes, ambos inclusive, el plazo para efectuar el pago voluntario será hasta el día 20 del mes siguiente o inmediato hábil posterior, y si se encuentra entre los días 16 y último de cada mes, ambos inclusive, el plazo del pago será hasta el 5 del segundo mes siguiente o inmediato hábil posterior.

De conformidad con lo establecido en el artículo 76.4 de la LOPDGDD y dado que el importe de la sanción impuesta es superior a un millón de euros, será objeto de publicación en el Boletín Oficial del Estado la información que identifique al infractor, la infracción cometida y el importe de la sanción.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa conforme al art. 48.6 de la LOPDGDD, y de acuerdo con lo establecido en el artículo 123 de la LPACAP, los interesados podrán interponer, potestativamente, recurso de reposición ante la Presidencia de la Agencia Española de Protección de Datos en el plazo de un mes a contar desde el día siguiente a la notificación de esta resolución o directamente recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

Finalmente, se señala que conforme a lo previsto en el art. 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

938-100325



Lorenzo Cotino Hueso
Presidente de la Agencia Española de Protección de Datos